

《信息系统安全》第十一讲

操作系统安全

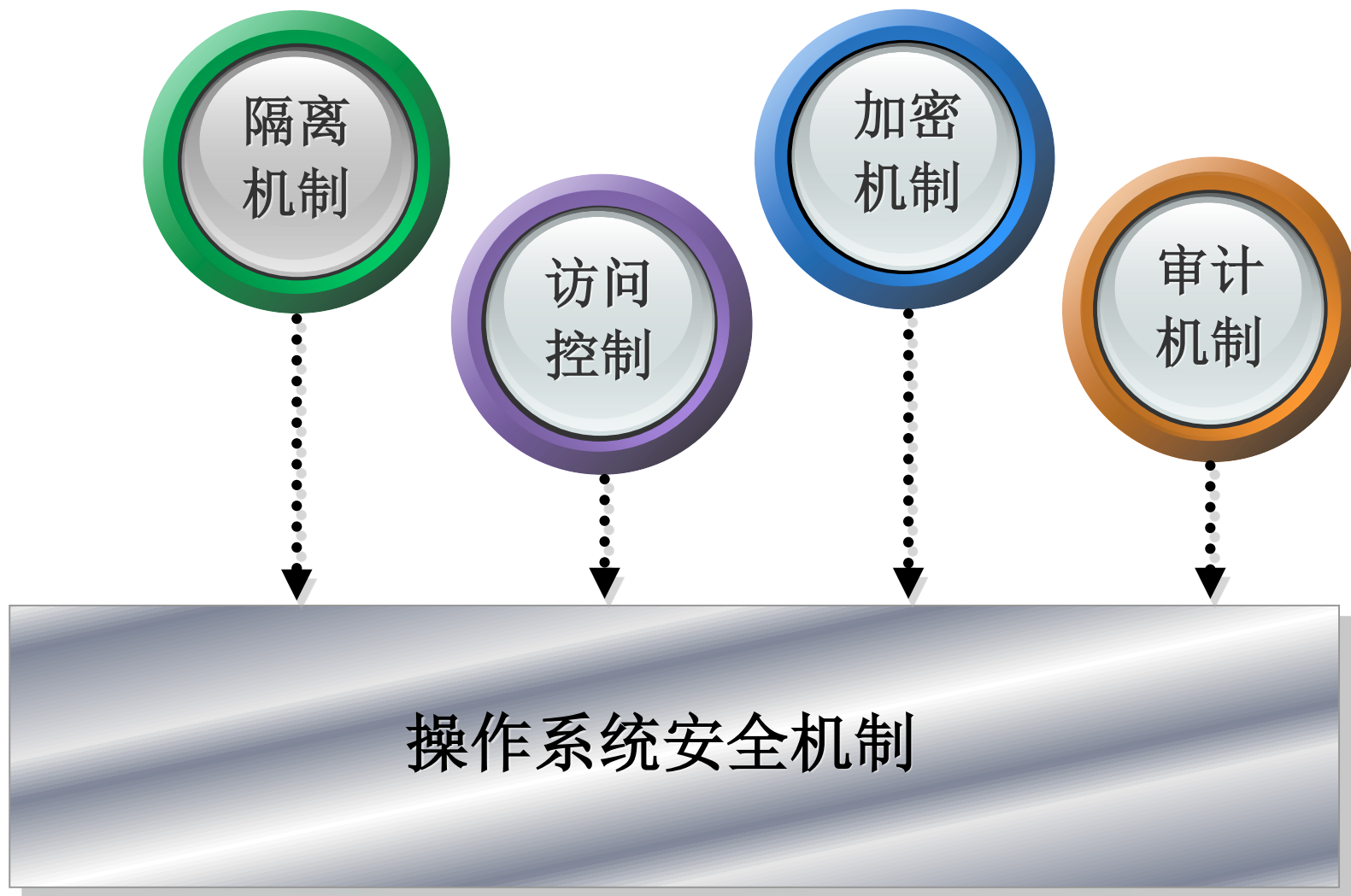
基于活动目录的域安全机制

2023年11月27日

周亚建

yajian@bupt.edu.cn

Overview of Last Class



这一讲要解决什么问题？



由于历史和技术发展方面的原因，现有企业内部的IT环境是逐步建立起来的，而且在早期建设时没有整体架构的科学指导，导致目前的松散型IT环境越来越“臃肿”，客户端、服务器各自独立，形成一个个信息“孤岛”，无法统一管理。

在松散型管理的网络环境中，一旦某个节点出现问题需要定位出现问题的位置，并需要繁琐费时的恢复过程来实现修复。应用软件的大规模部署需要相关人员在各个计算机上逐一手工安装，极其耗费人力与时间。

这一讲要解决什么问题？

- 如何能快捷地实现安全配置？
- 如何管理大型、复杂信息系统的资源？



组策略是微软Windows NT家族操作系统的一个特性，它可以控制用户账户和计算机账户的工作环境。组策略提供了操作系统、应用程序和活动目录中用户设置的集中化管理和配置。

主要应用于Windows 2000及以上版本操作系统。

这一讲要解决什么问题？

目录服务

01

AD能做什么？

02

活动目录概述

AD的逻辑结构

04

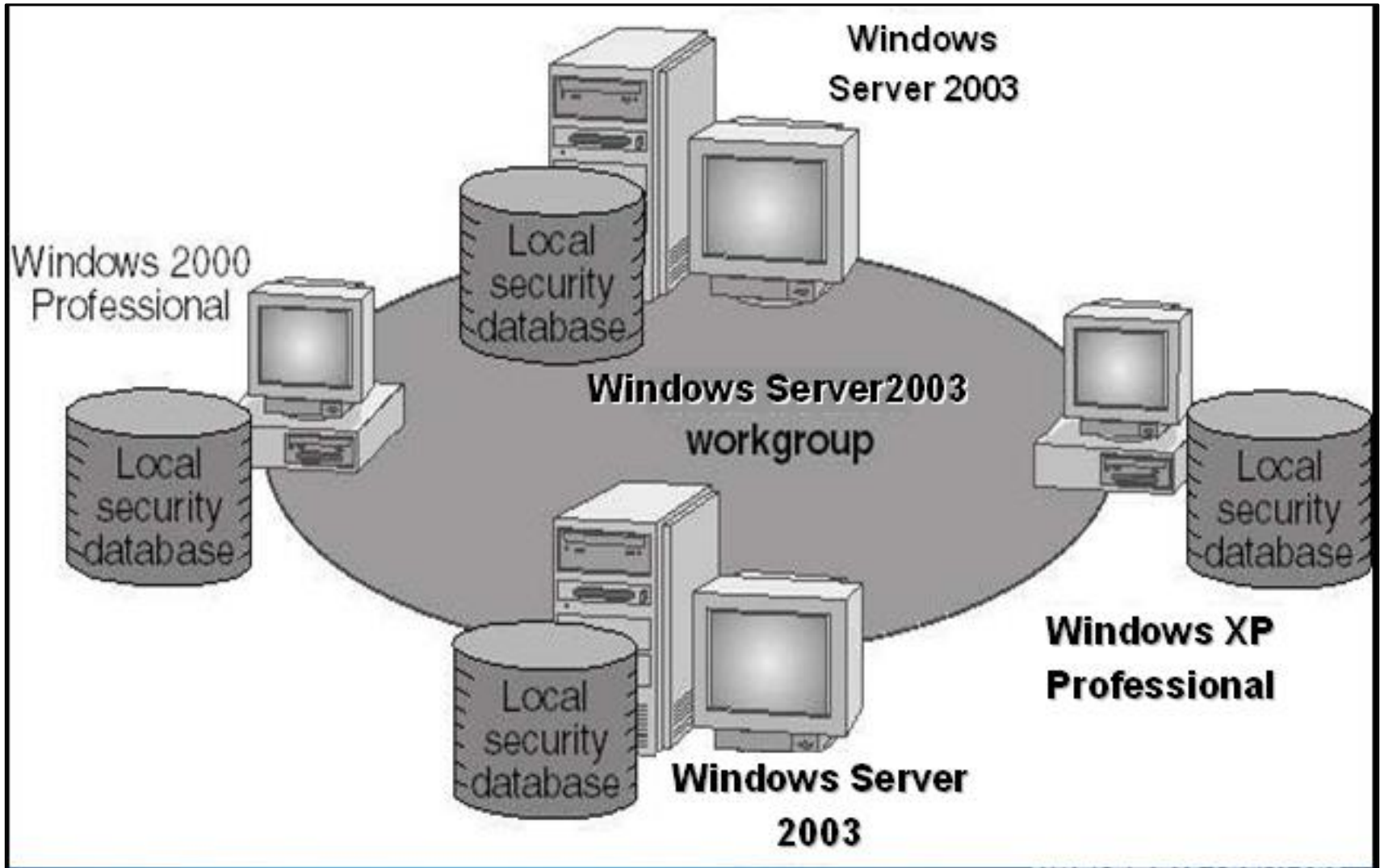
AD的物理结构

03



Windows域

Windows对IT资源管理方式



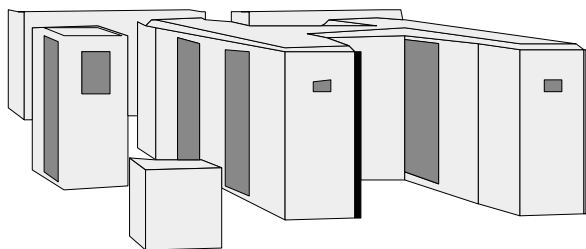
为什么需要域？



我们这时要考虑一个问题，为什么工作组就不适合中大型网络呢，难道每台计算机分散管理不好吗？

为什么需要域：一个实例

假设现在工作组内有两台计算机：



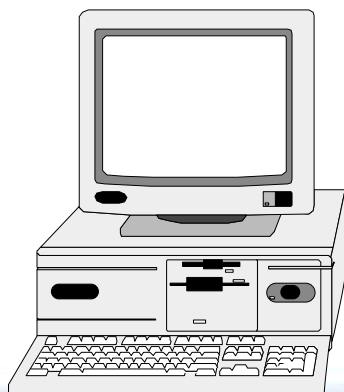
服务器提供的资源有多种形式，
可以是共享文件夹、共享打印
机、电子邮箱、数据库等等

一台是服务器Florence

职能：提供资源和分配资源。

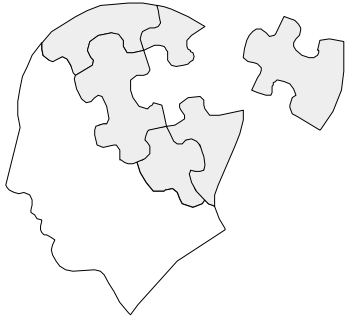
假设服务器Florence提供一个简单的共享文
件夹作为服务资源。

任务：要把这个共享文件夹的访问权限授予
公司内的员工张建国（注意，这个文件夹只
有张建国一个人可以访问！）



一台是客户机Perth

Workgroup管理模型



一般情况下管理员的思路:

在服务器上为张建国这个用户创建一个用户账号，如果访问者能回答出张建国账号的用户名和密码，服务器就认可这个访问者就是张建国。



Workgroup管理模型



接下来张建国就在客户机Perth上准备访问服务器上的共享文件夹，他准备访问资源\\Florence\\人事档案，服务器对访问者提出了身份验证请求。

Workgroup管理模型

张建国成功地通过了身份验证，访问到了目标资源。



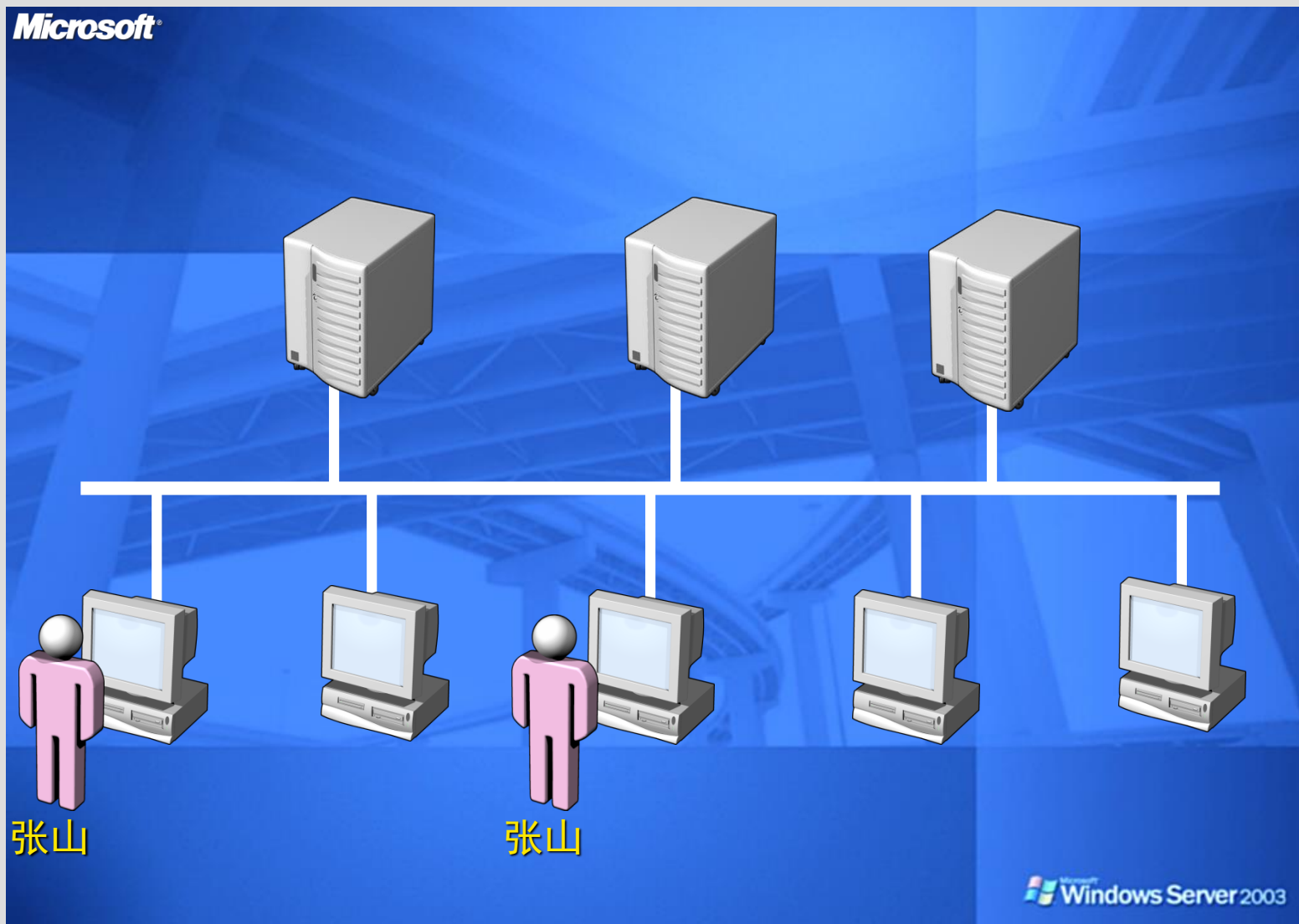
问题的扩展



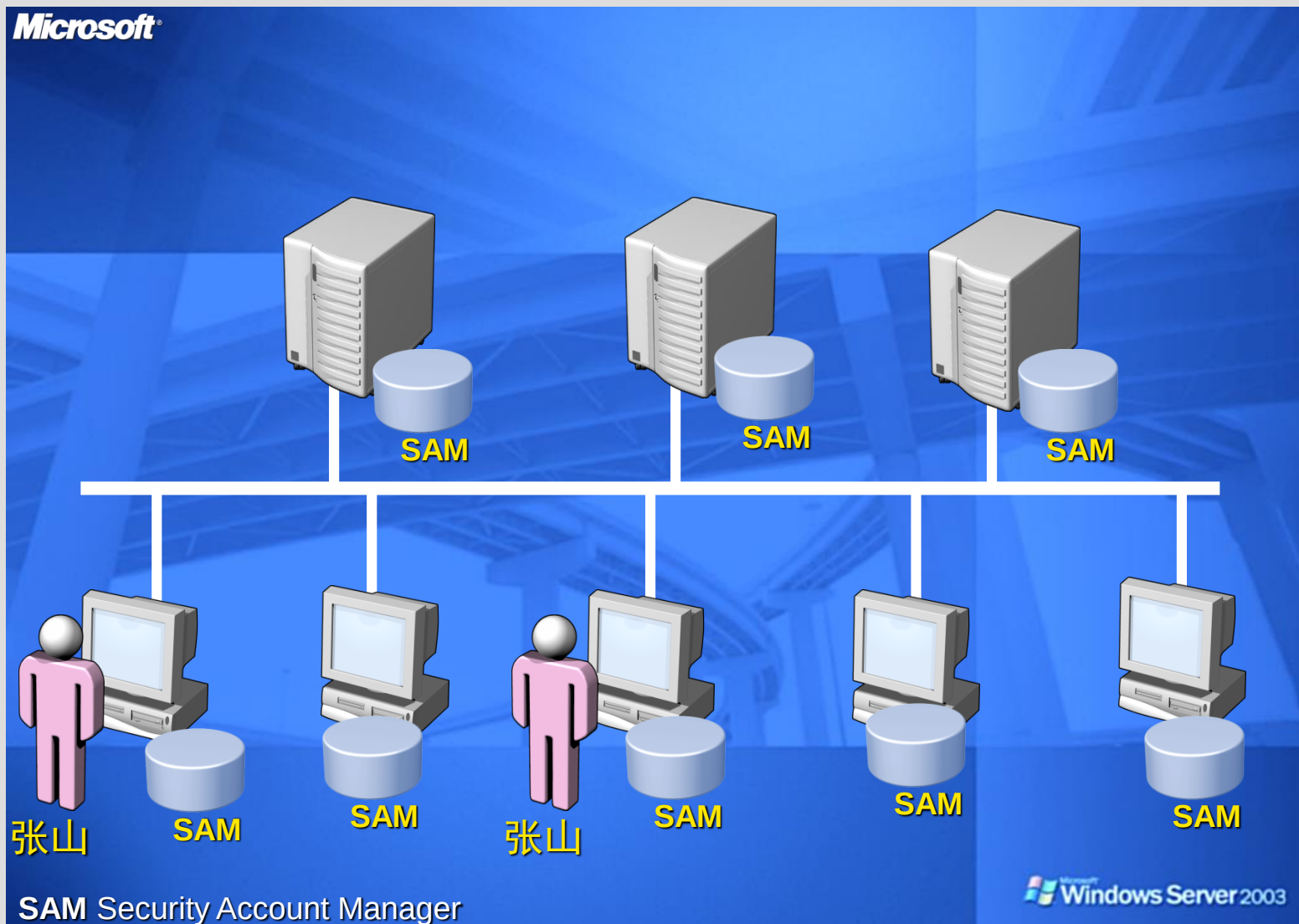
假设公司不是一台服务器，而是10台服务器，这大致是一个中型公司的规模

如果这10台服务器上都有资源要分配给张建国，那会有什么样的后果呢？

产生活动目录的背景



产生活动目录的背景



问题的扩展

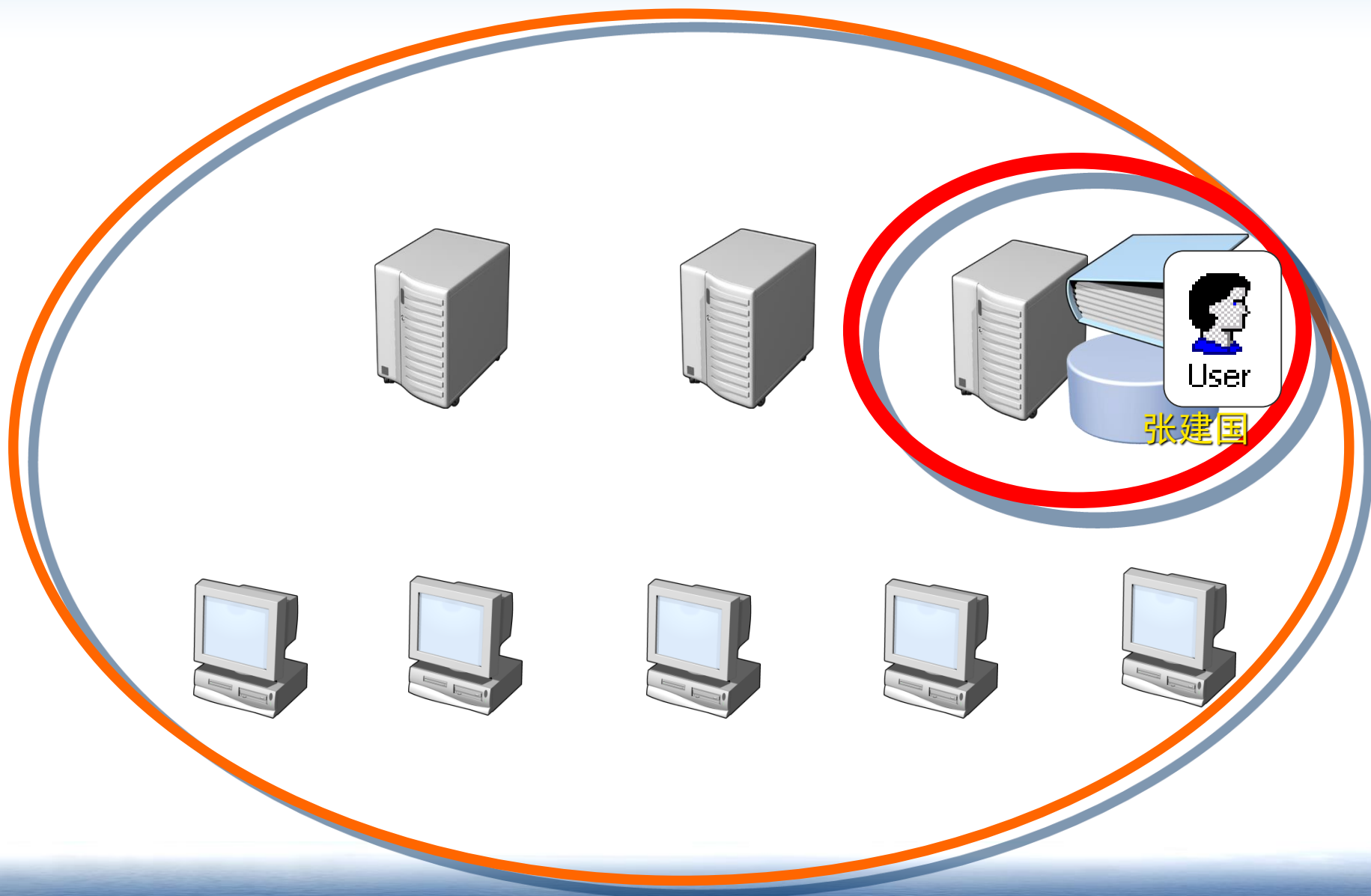


- 假设公司不是一台服务器，而是500台服务器，这大致是一个中型公司的规模
- 如果这500台服务器上都有资源要分配给张建国，那会有什么样的后果呢？

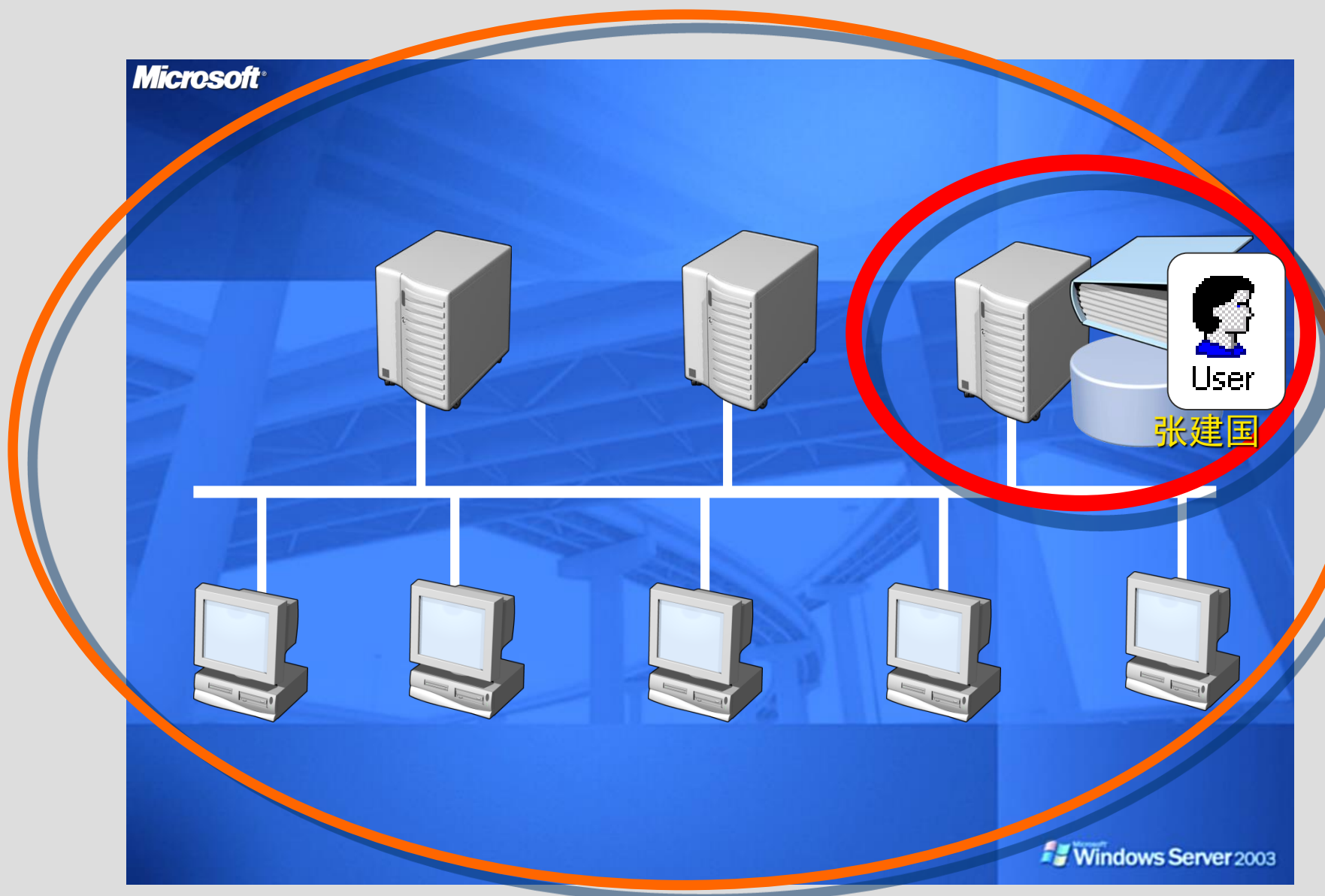


假设公司有1000名员工呢？

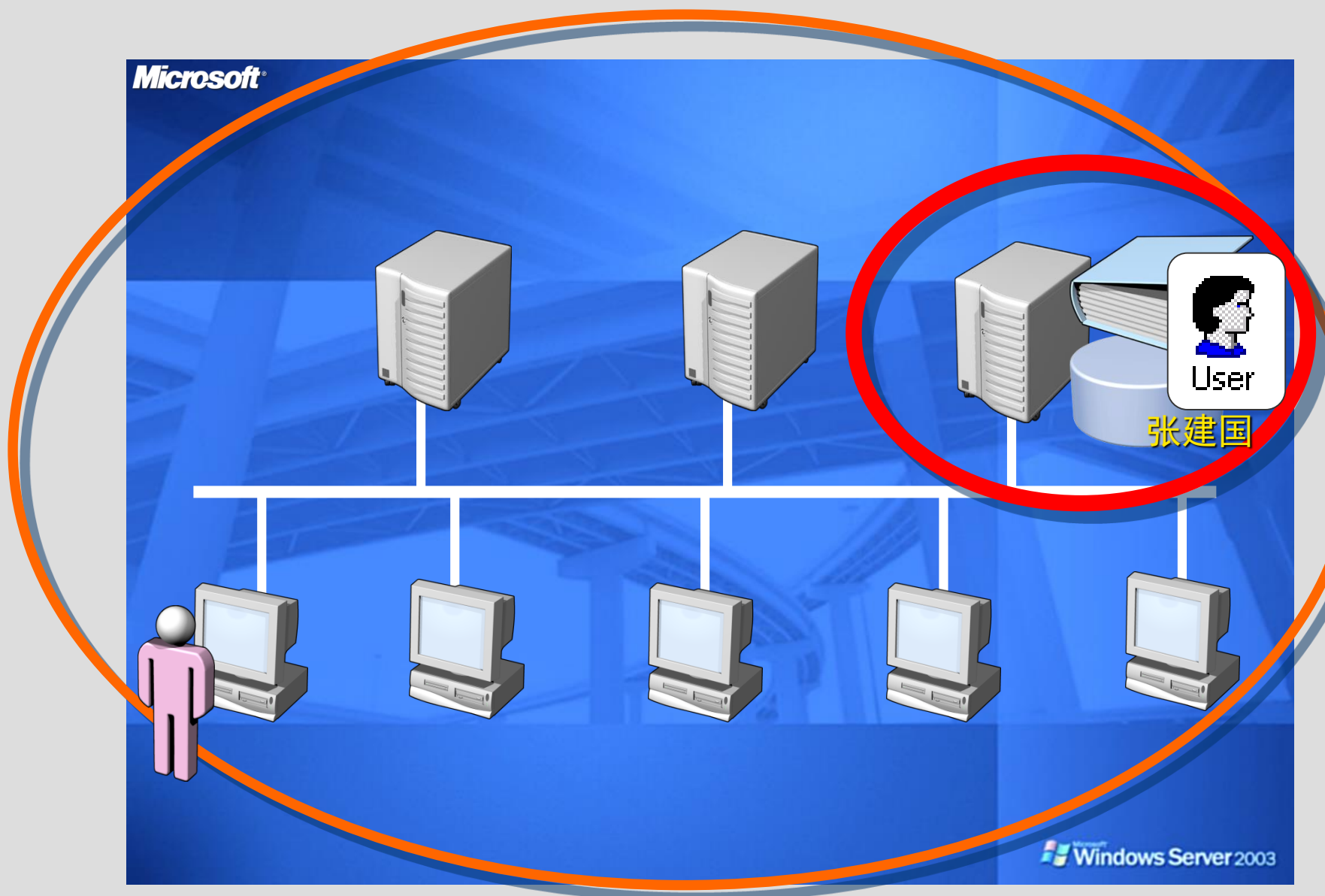
我们需要什么样的解决方案？



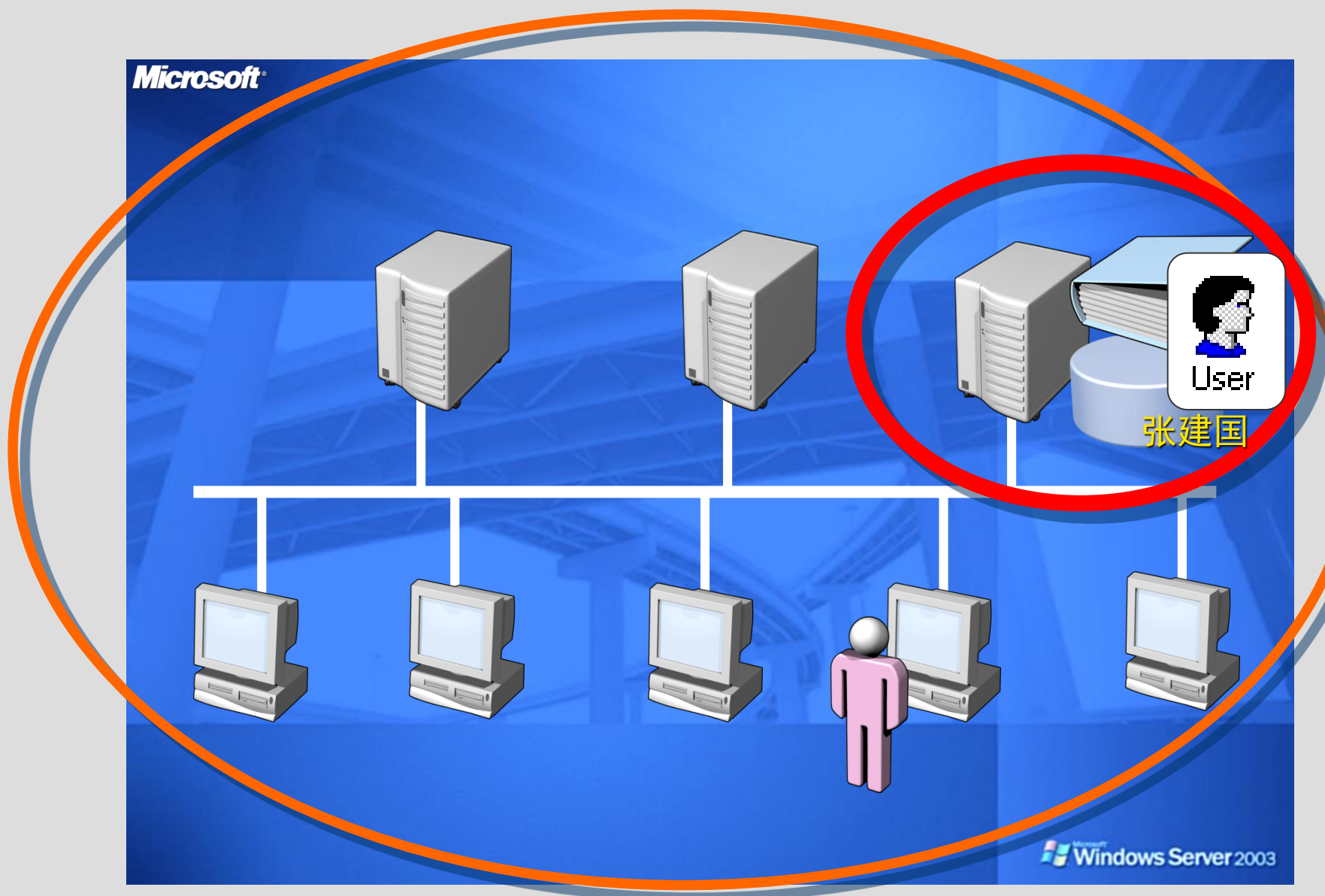
活动目录的概念 – 从域讲起



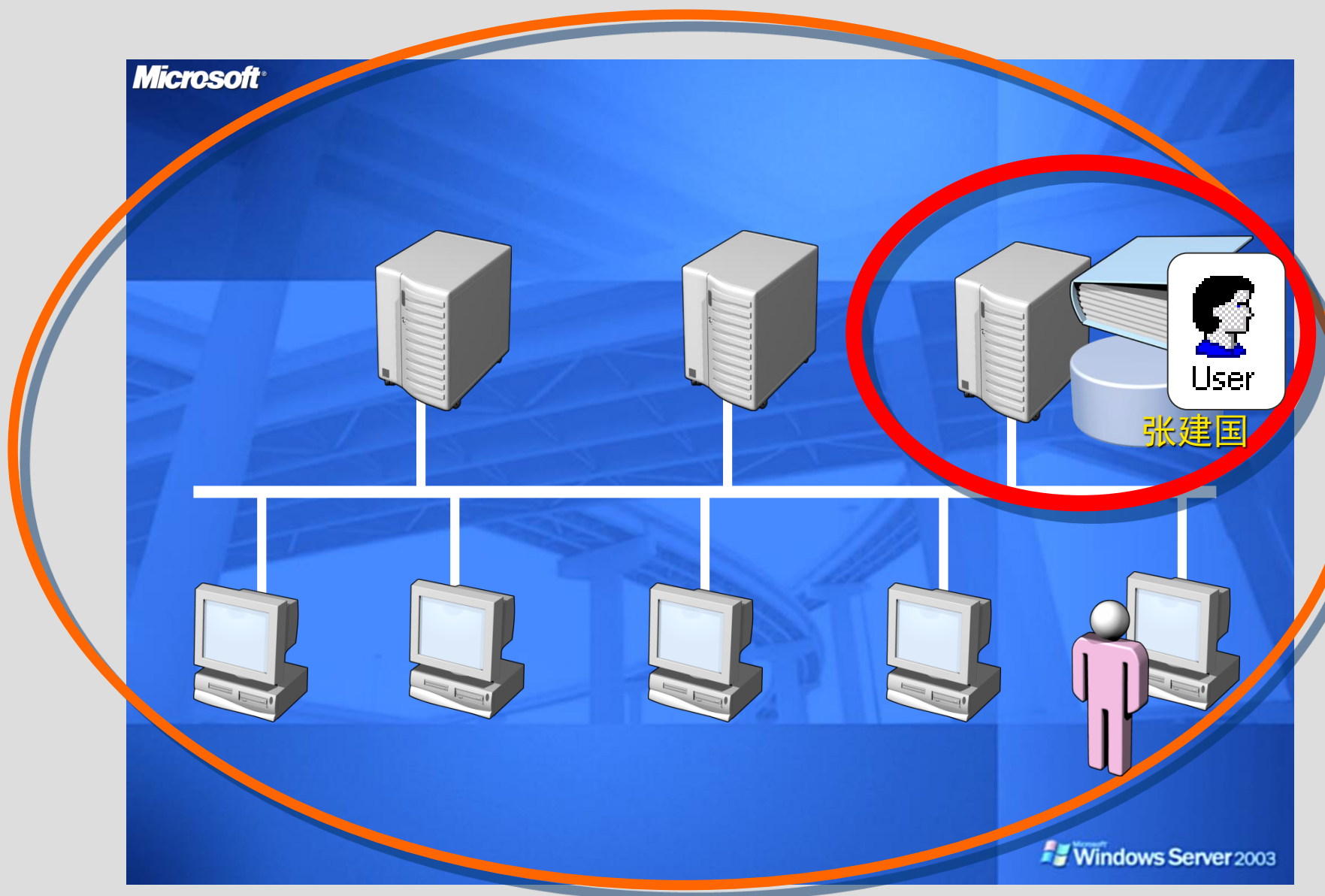
活动目录的概念 – 从域讲起



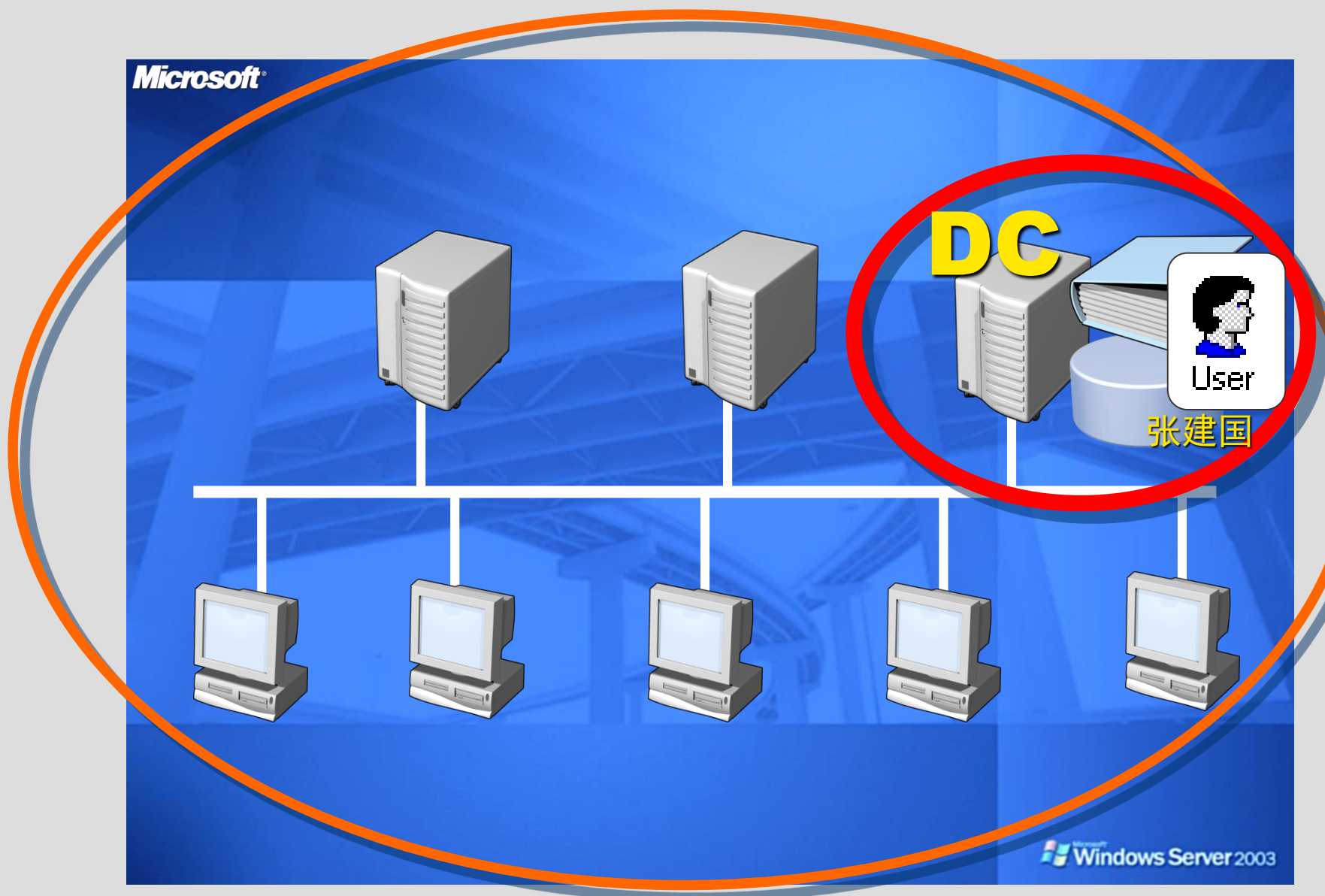
活动目录的概念 – 从域讲起



活动目录的概念 – 从域讲起



活动目录的概念 – 从域讲起



解决问题的思路

用户账号等资源实现共享

只要有一台计算机为公司员工创建了用户账号，其他计算机就可以共享账号了。这样就很好地解决了账号重复创建的问题。



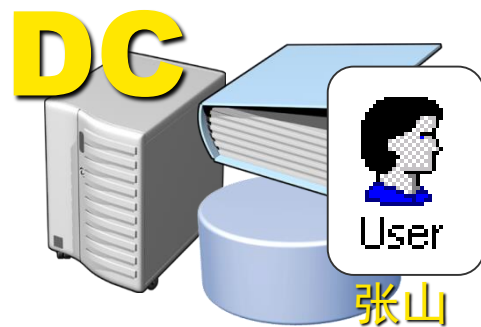
难道无限制，anytime, anywhere?

问题的解决：域

域就是共享用户账号、计算机账号和安全策略的计算机集合。

- 域是一个安全边界
资源在一个域中参与共享。

域中集中存储用户账号的计算机就是域控制器，域控制器存储着目录数据并管理用户域的交互关系，包括用户登录过程、身份验证和目录搜索等。

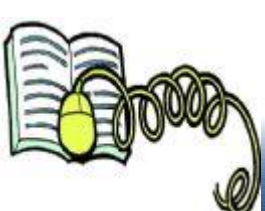
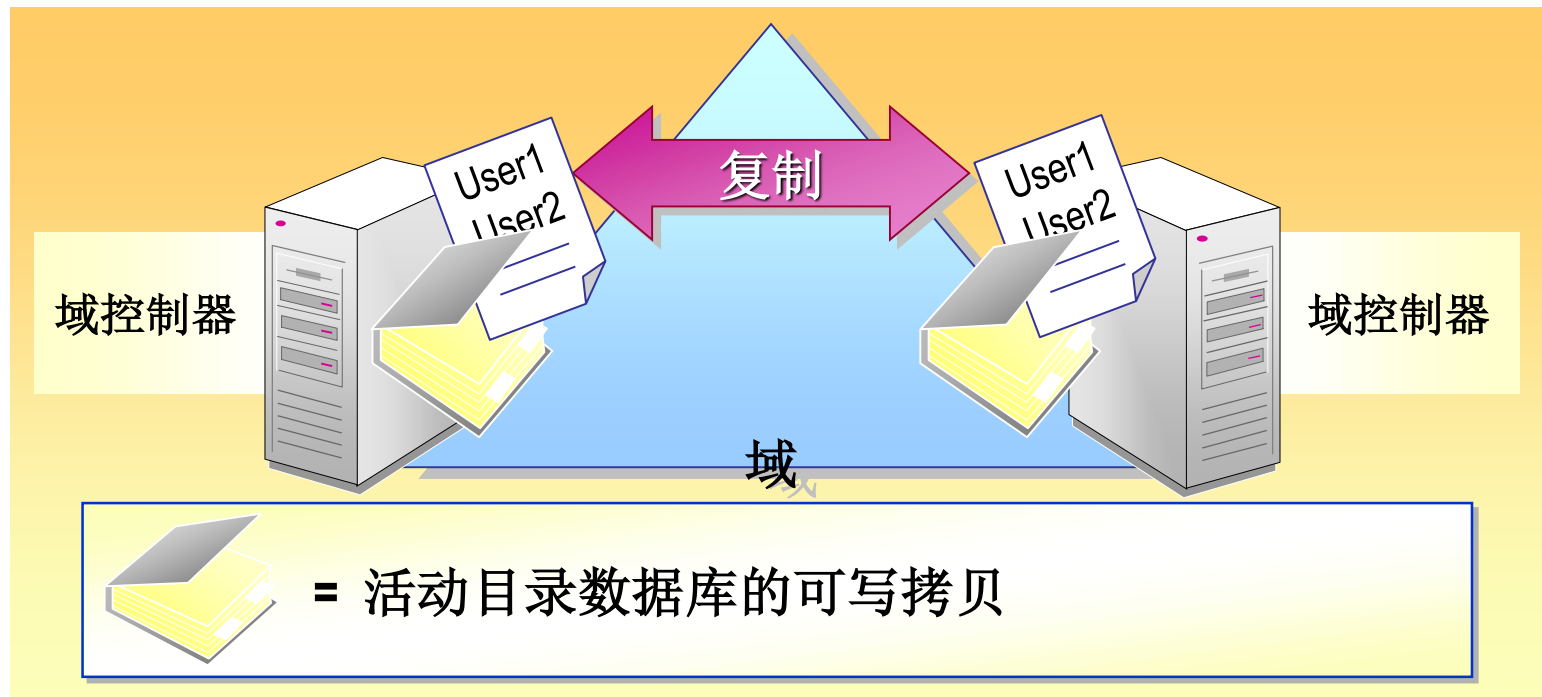


域模型就是针对大型网络的管理需求而设计的

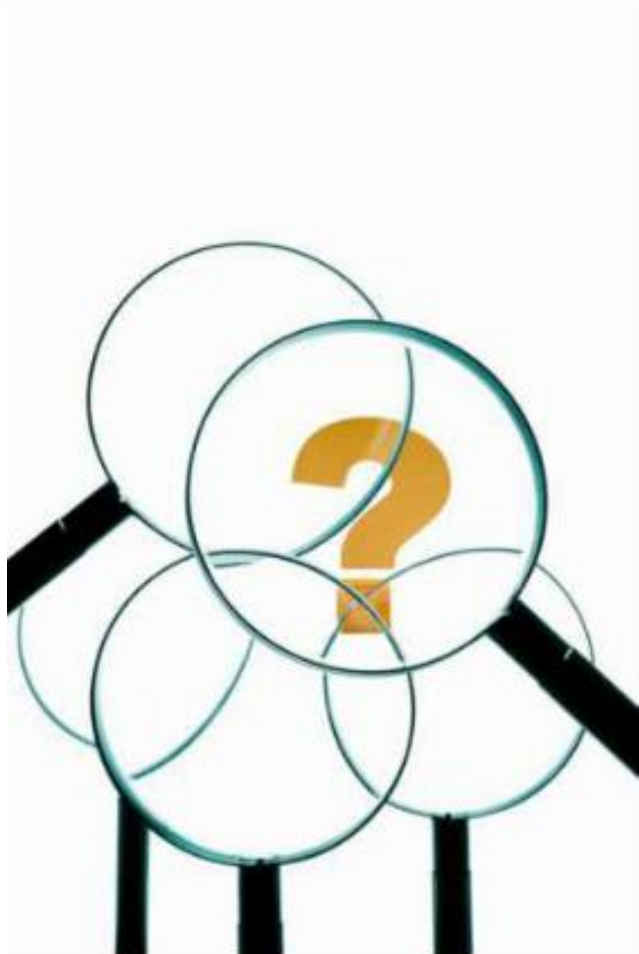
活动目录和域控制器

冗余 热备份 双机热备份可靠度99.95%

一个域中可有一个或多个域控制器，各域控制器间可以相互复制活动目录



另一个问题



怎么实现用户账号、计算机账号和安全策略等各种资源的共享？

可能的解决方案

将网络中的各种网络设备、网络服务、网络账号等资源信息集中起来进行管理，为用户提供一个统一的清单。



目录
服务

计算机
网络设备
打印设备
共享文件
共享打印
网络账户

.....

Windows 2003 Server管理网络上众多资源，提供对系统资源及服务的跟踪定位，使各种资源和服务对用户透明，用户不必知道资源的具体位置就能方便地访问它们。

问题的解决方案：活动目录

Microsoft

域 Domain

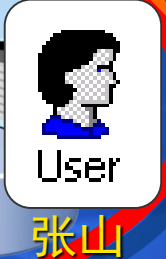
活动目录 Active Directory

DC

DC



张山



张山

用户账号、计算机账号和安全策略被存储在域控制器上一个名为Active Directory的数据库中

Windows Server 2003

What is Active Directory?



WIKIPEDIA
The Free Encyclopedia

[Main page](#)

[Contents](#)

[Featured content](#)

[Current events](#)

[Random article](#)

[Donate to Wikipedia](#)

▼ [Interaction](#)

[Help](#)

[About Wikipedia](#)

[Community portal](#)

[Recent changes](#)

[Contact Wikipedia](#)

Structure [\[edit\]](#)

Objects [\[edit\]](#)

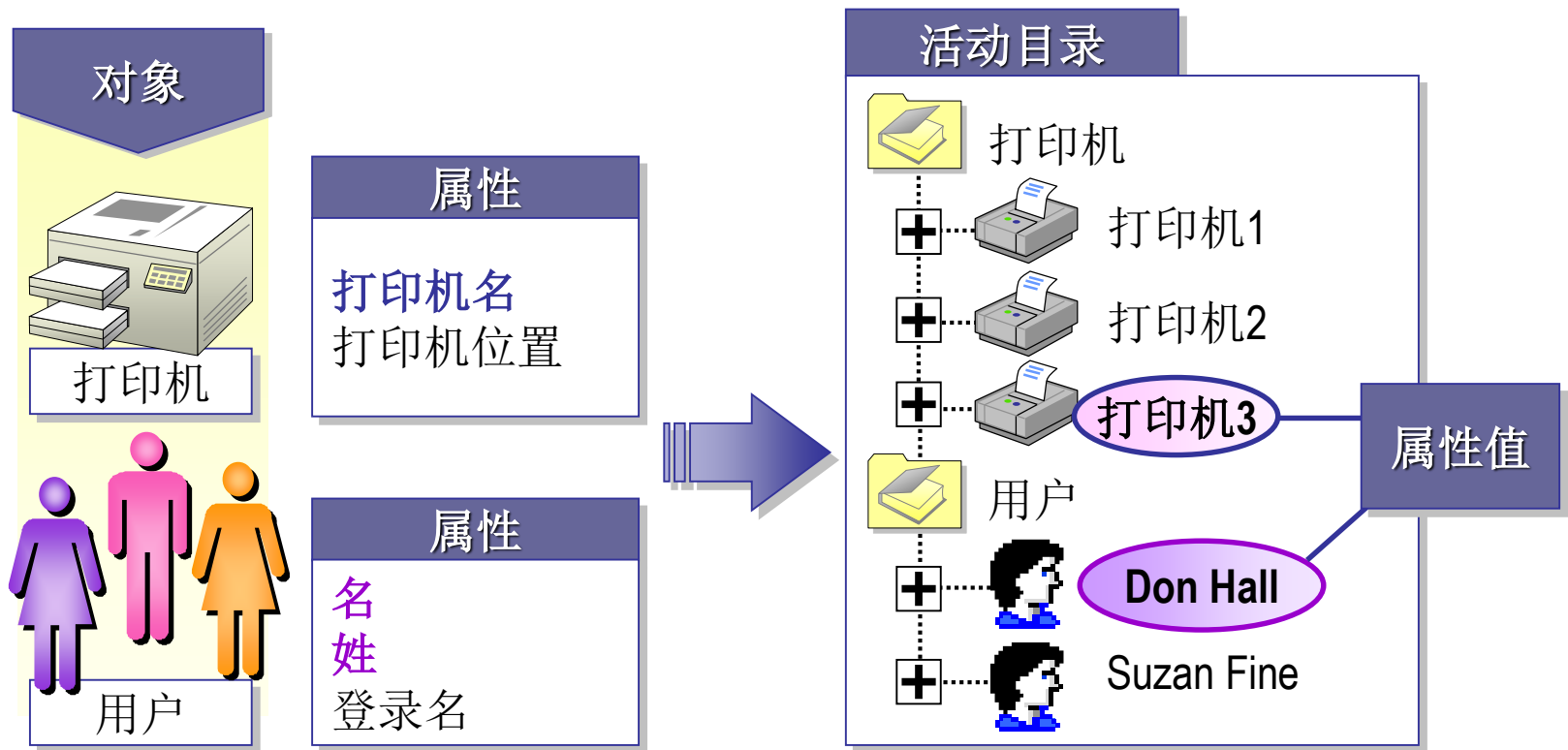
An Active Directory structure is a hierarchical arrangement of information about [objects](#). The objects fall into two broad categories: resources (e.g., printers) and [security principals](#) (user or computer accounts and groups). Security principals are assigned unique [security identifiers](#) (SIDs).

Each object represents a single entity—whether a user, a computer, a printer, or a group—and its attributes. Certain objects can contain other objects. An object is uniquely identified by its name and has a set of attributes—the characteristics and information that the object represents—defined by a [schema](#), which also determines the kinds of objects that can be stored in Active Directory.

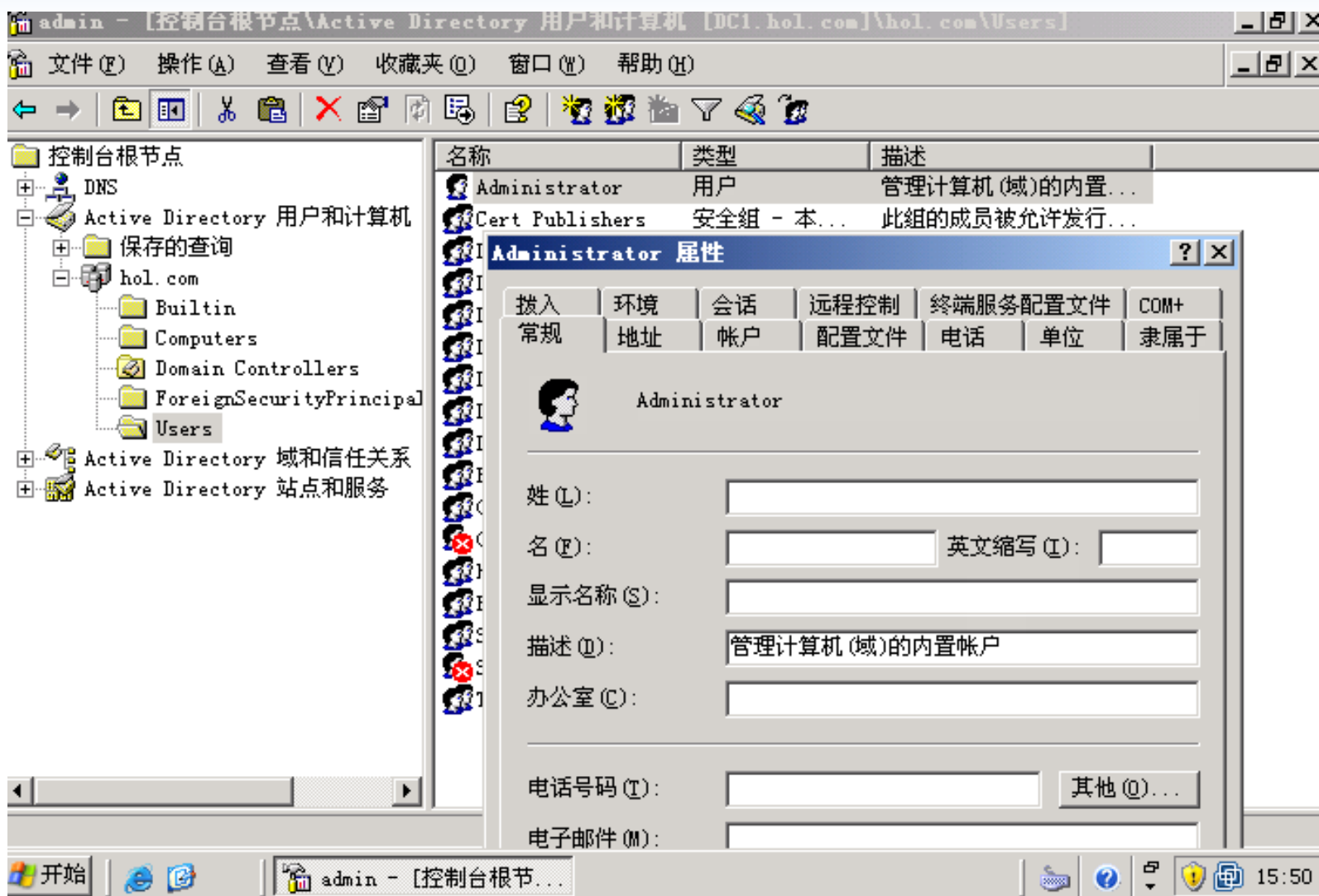
The [schema object](#) lets administrators extend or modify the schema when necessary. However, because each schema object is integral to the definition of Active Directory objects, deactivating or changing these objects can fundamentally change or disrupt a deployment. Schema changes automatically propagate throughout the system. Once created, an object can only be deactivated—not deleted. Changing the schema usually requires planning.^[2]

活动目录的数据库

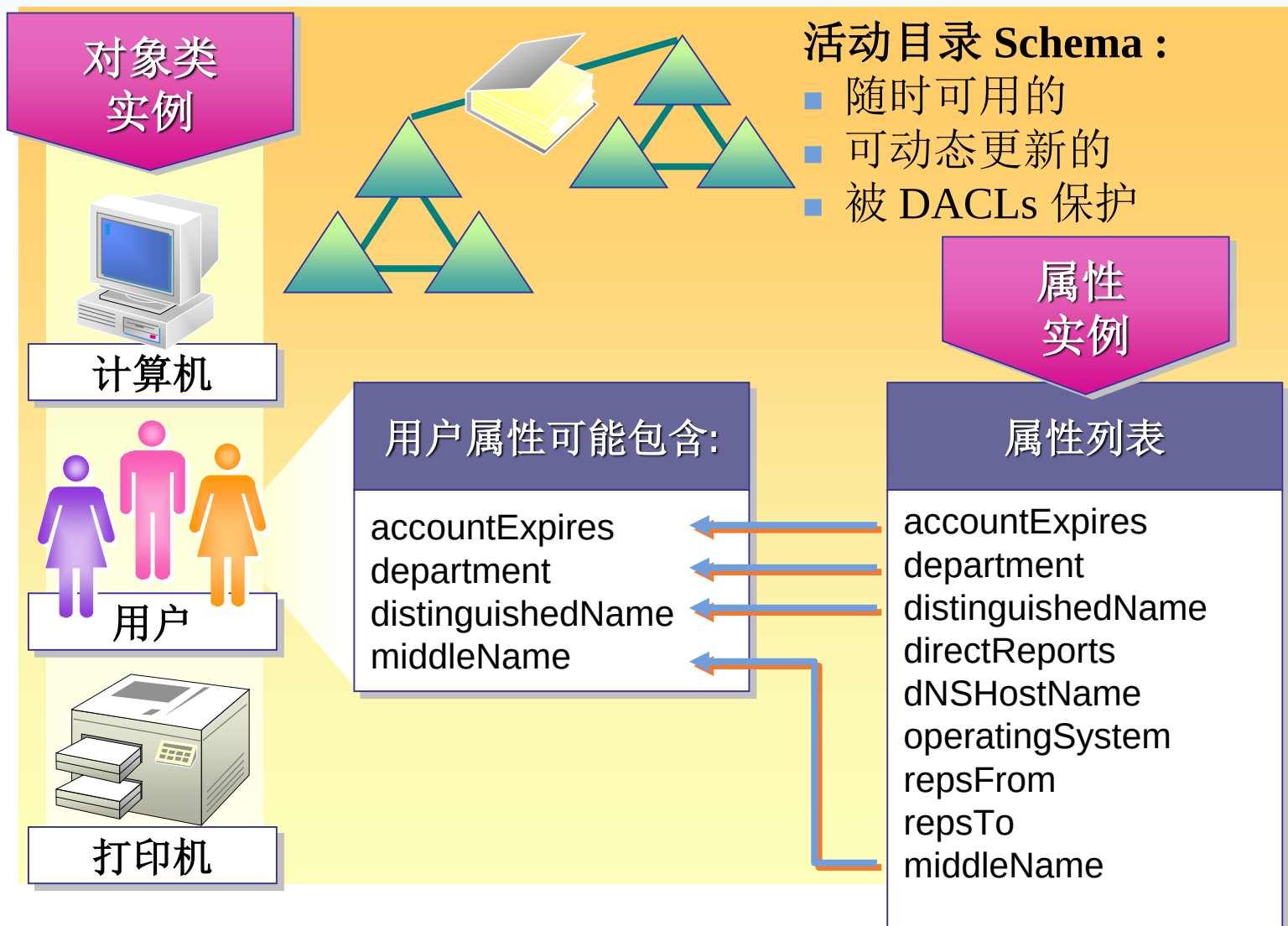
活动目录中存储：对象，属性



使用“活动目录和计算机”工具查看对象

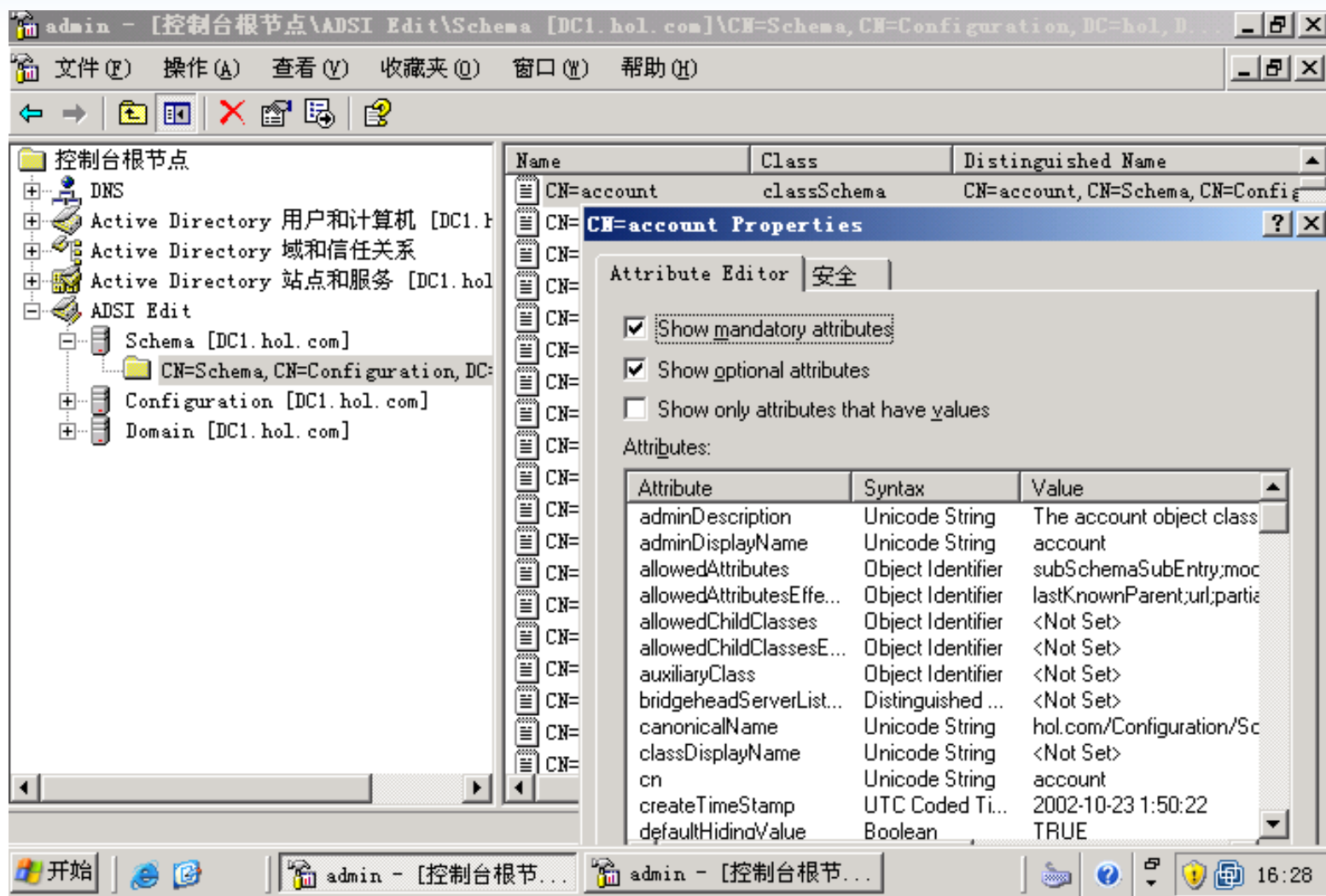


Schema（架构）



架构用来定义AD中的对象（**classes**）和属性（**attributes**）。活动目录的基础架构（**base Schema**）包括了比如**user**、**computer**、**OU**（**organizational Unit**）等对象以及用户电话号码、**objectsid**等属性。

使用ADSI EDIT查看Schema信息



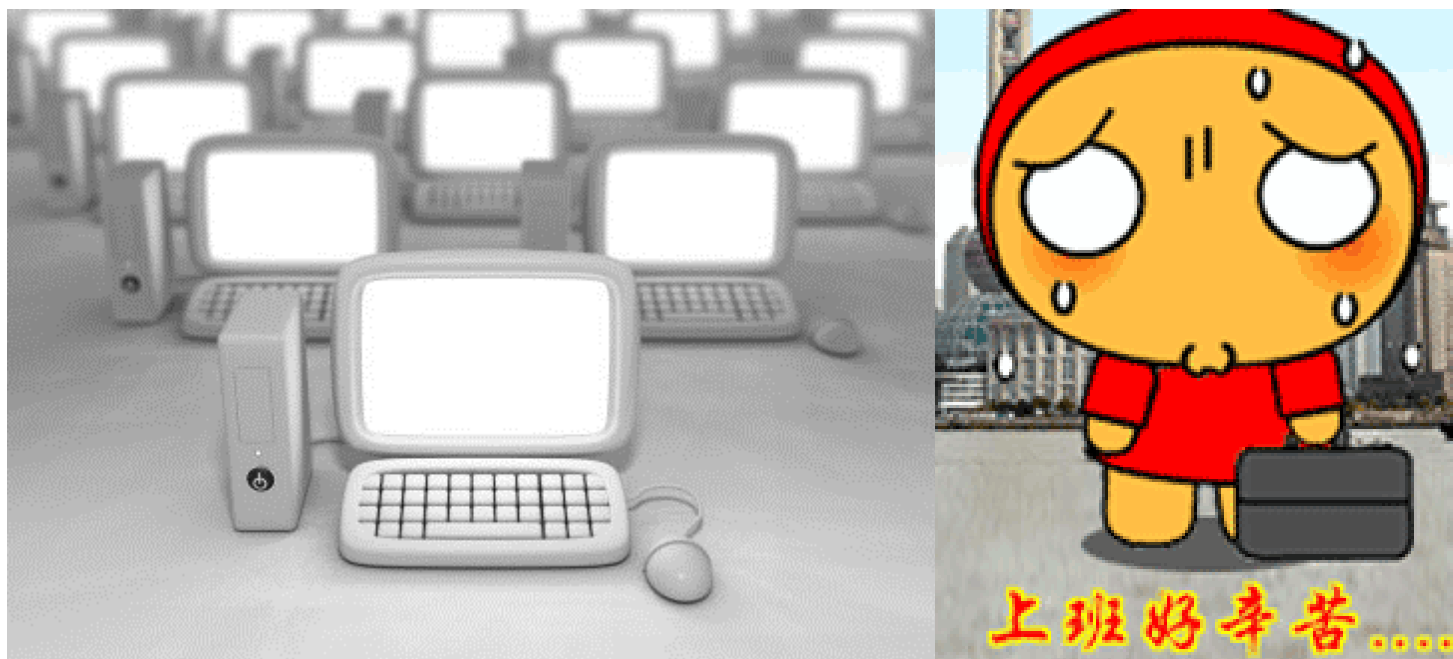
什么时候适合部署AD

微软认为，当一个计算机网络中的计算机数量超过20台式时，就应该使用AD来管理这个网络了。



什么时候适合部署AD

网络中的计算机数量过于庞大，在针对桌面型维护如软件安装、系统补丁升级、关键应用的实施时，IT维护人员的工作量剧增，以致影响企业正常运转。

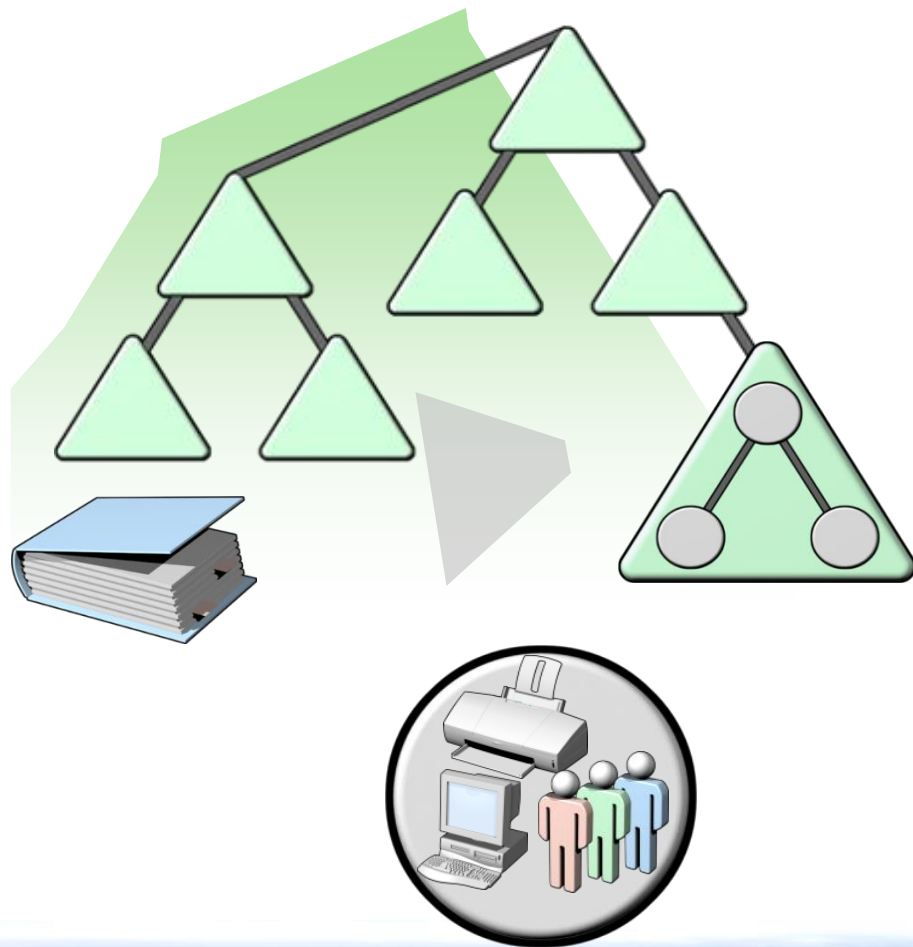


这时需要AD来做程序的下发工作

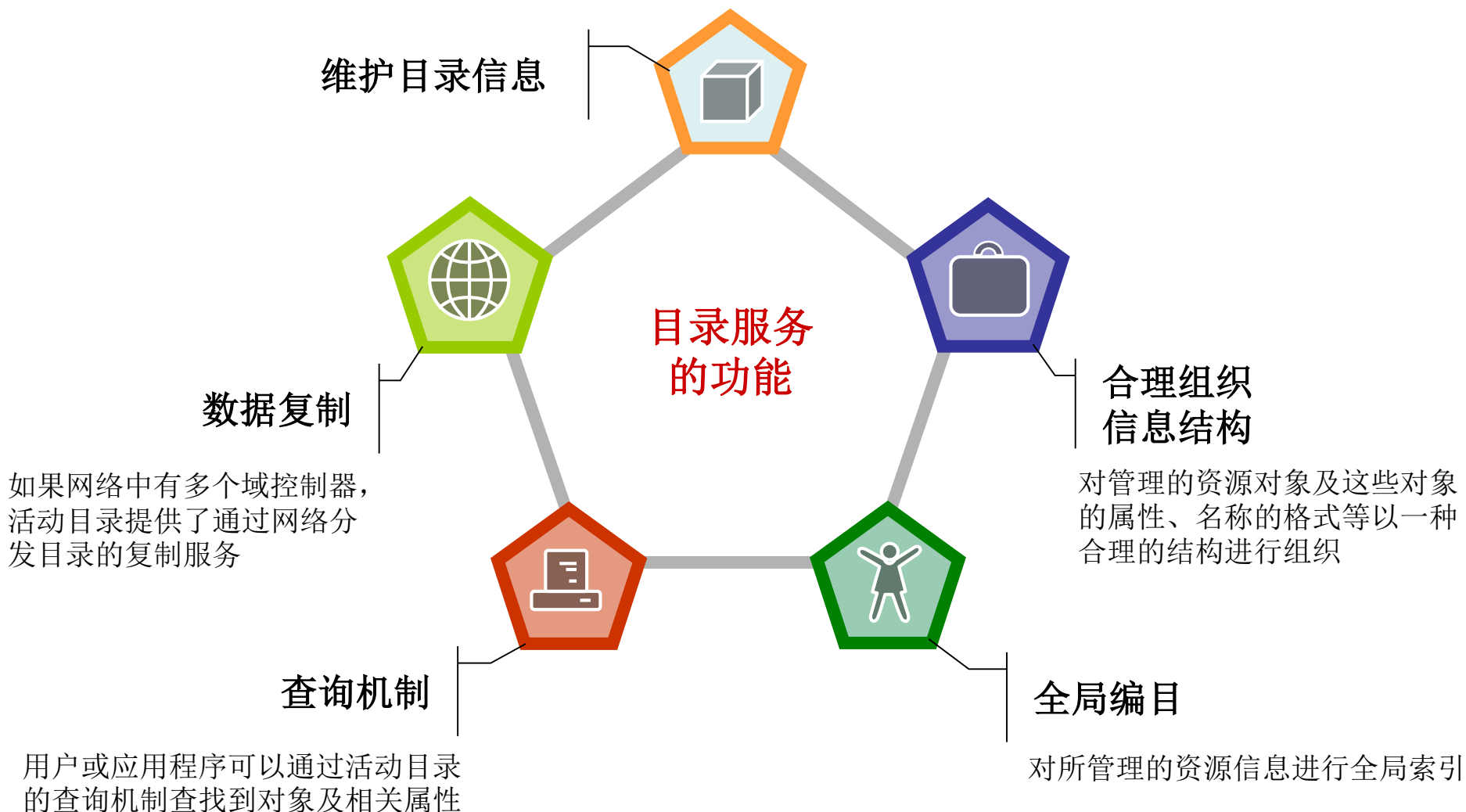
活动目录 vs. 目录服务

- 活动目录就其本质来讲，是一种采用LDAP（轻量级目录访问协议）的目录服务
- 活动目录包括两个方面
 - 目录
 - 目录相关的服务

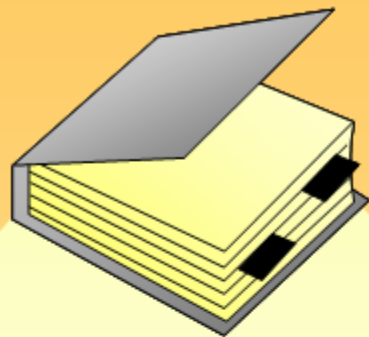
- 目录是存储各种对象的容器
保存集中管理的共享资源信息，
包括服务器信息、文件信息、打印机信息、用户账号等信息



目录服务



为什么需要目录服务



目录服务的 功能性

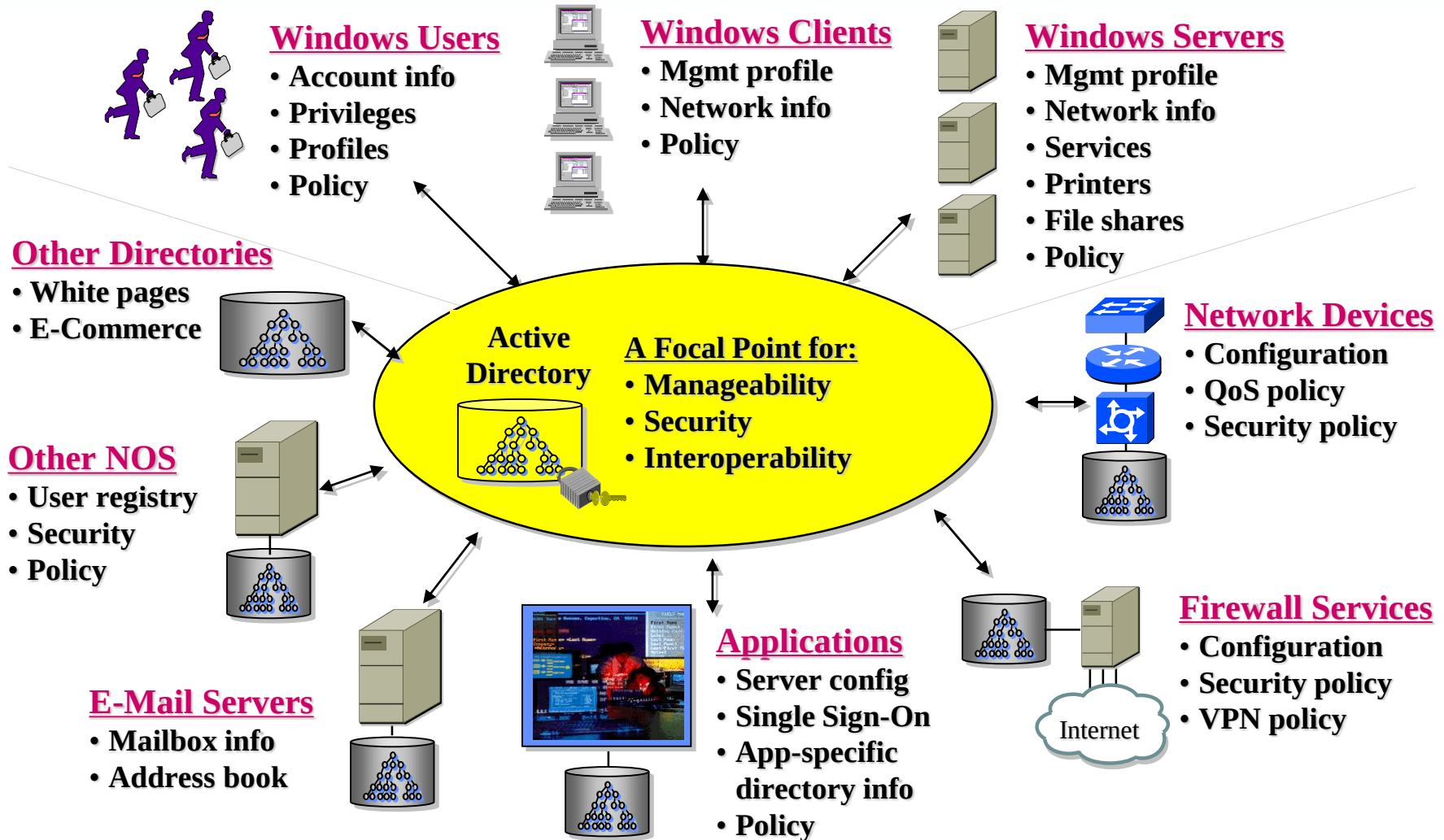
- 组织
- 管理
- 控制

资源

集中式的管理

- 单入口的管理
- 一次登陆，可访问域中所有资源

A Summary: 活动目录的地位



是安全体系、管理结构以及资源组织的中心



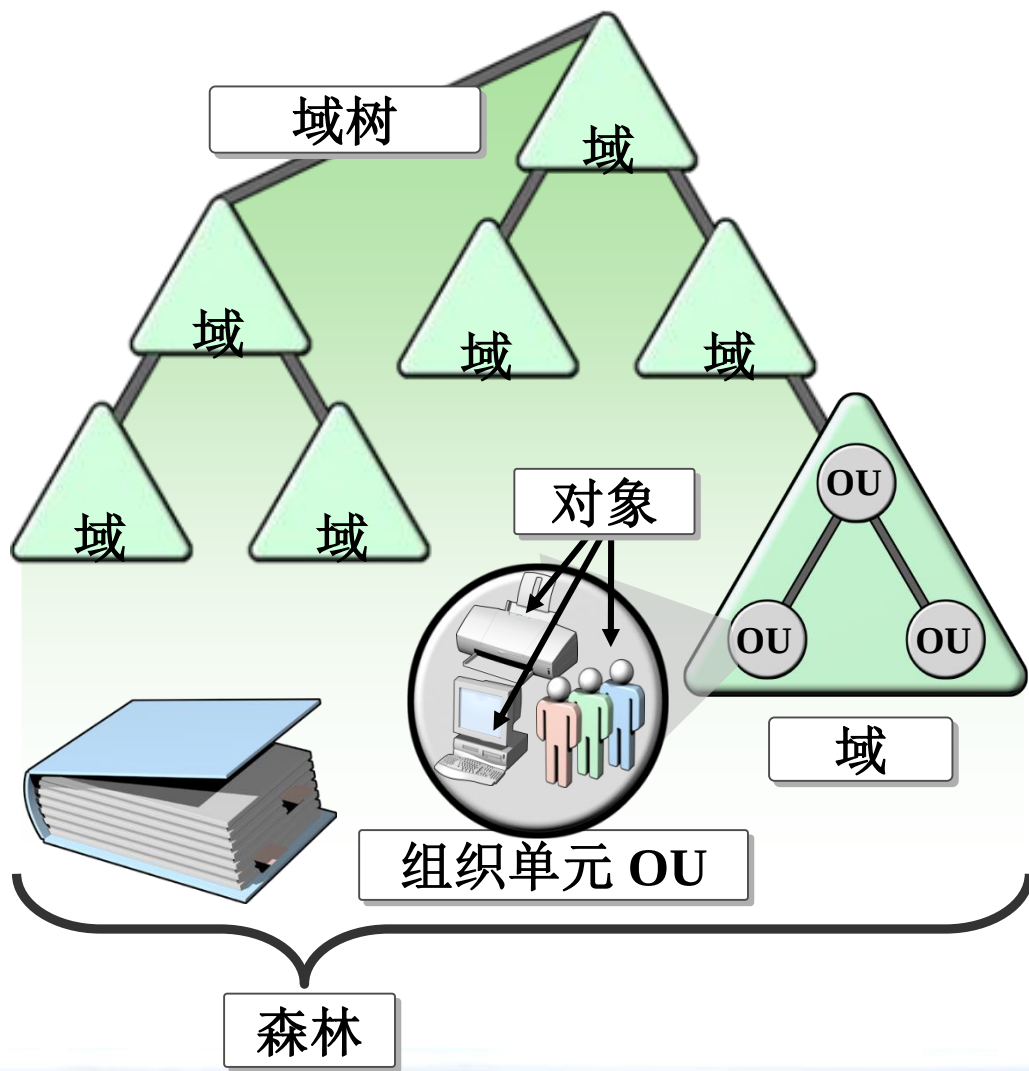
活动目录 的结构

活动目录的结构



An Active Directory structure is a hierarchical arrangement of information about objects.

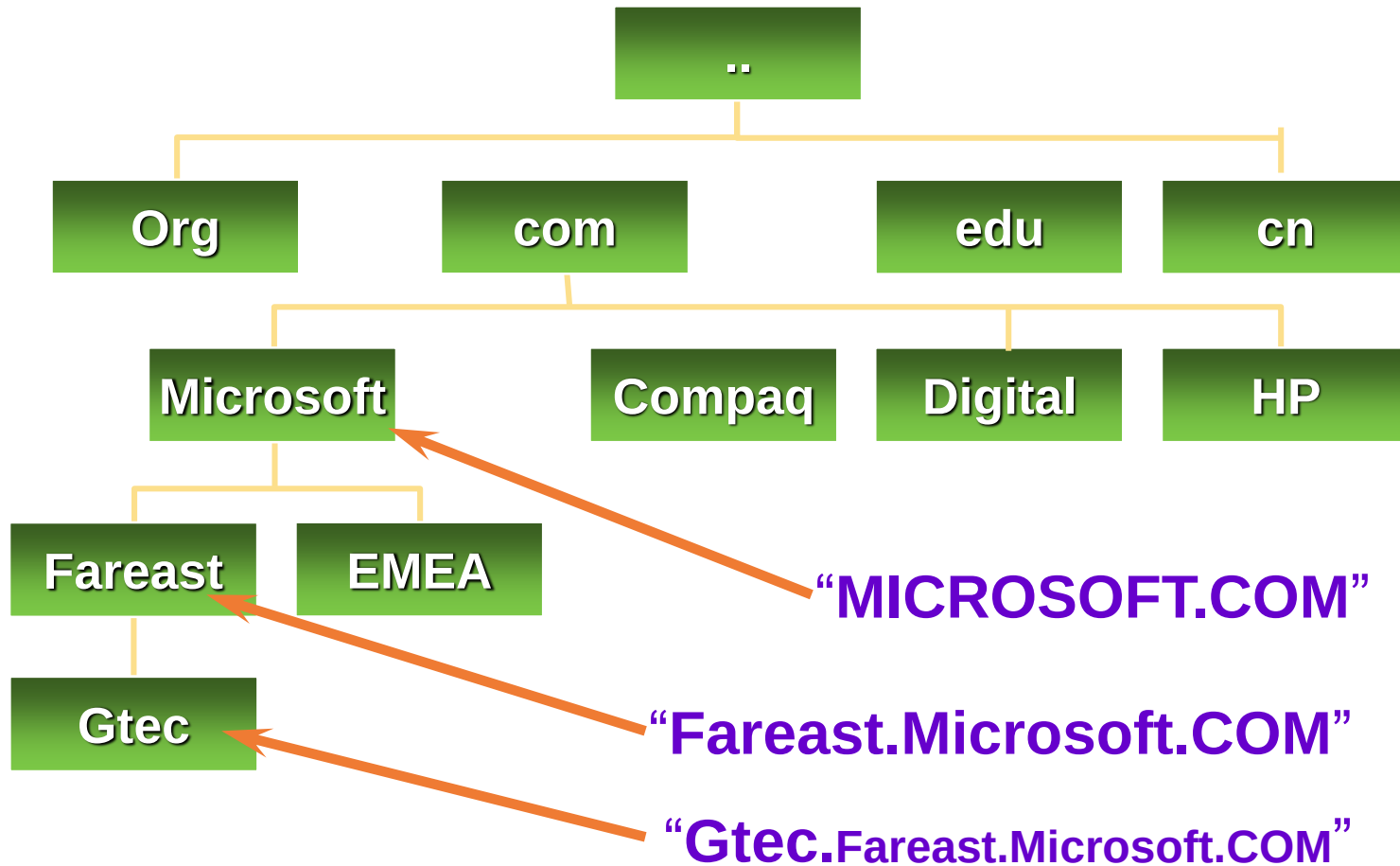
活动目录的逻辑结构



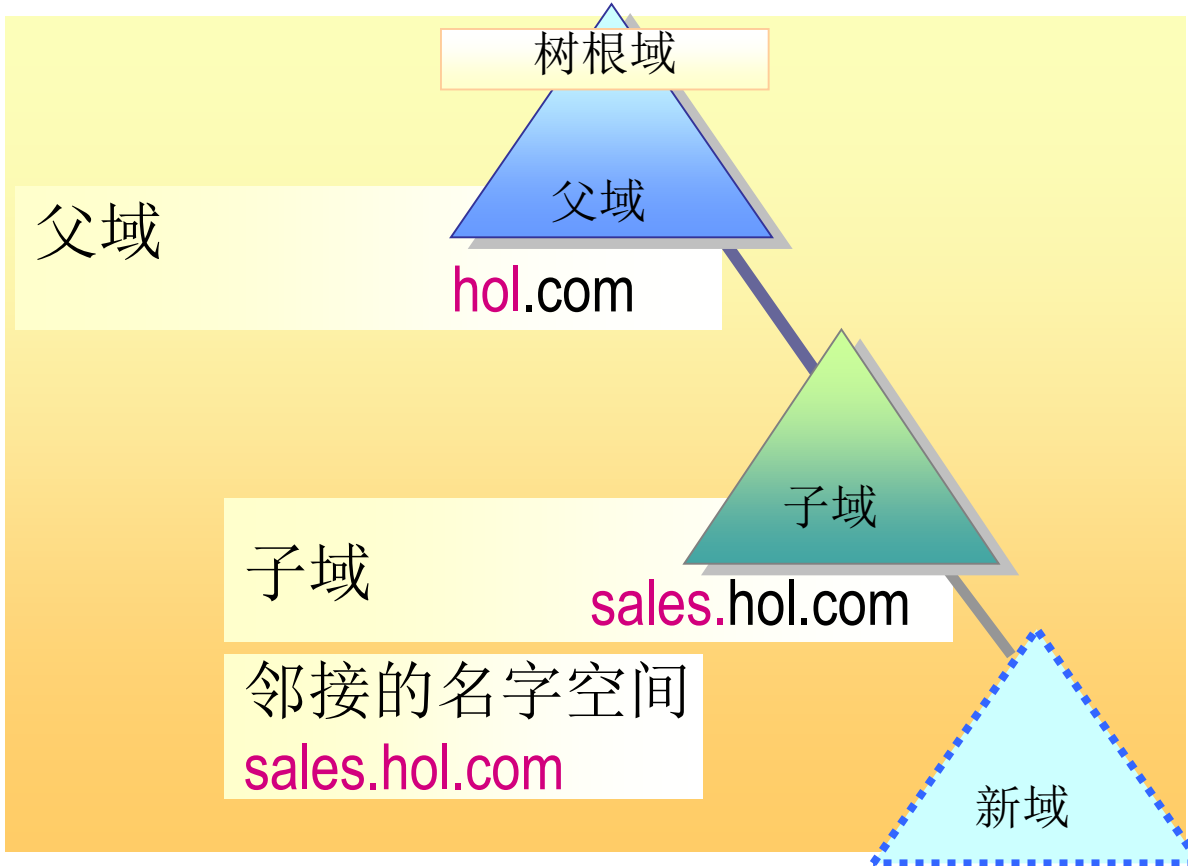
- 森林 (Forests)
- 树 (Trees)
- **域 (Domains)**
- 组织单元 (OU)
- 对象 (Objects)



逻辑结构：域的层次结构

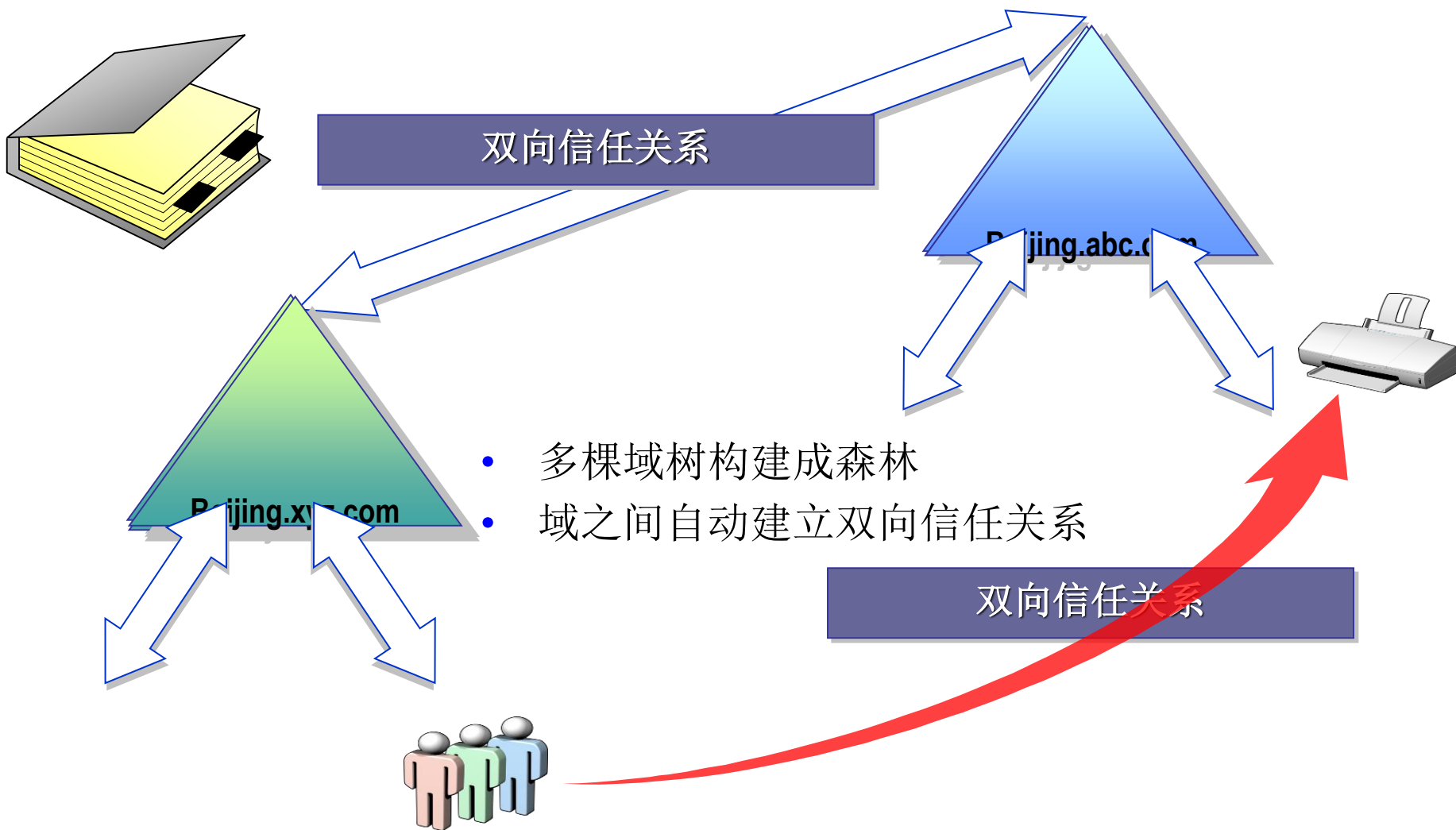


域树 (Tree)



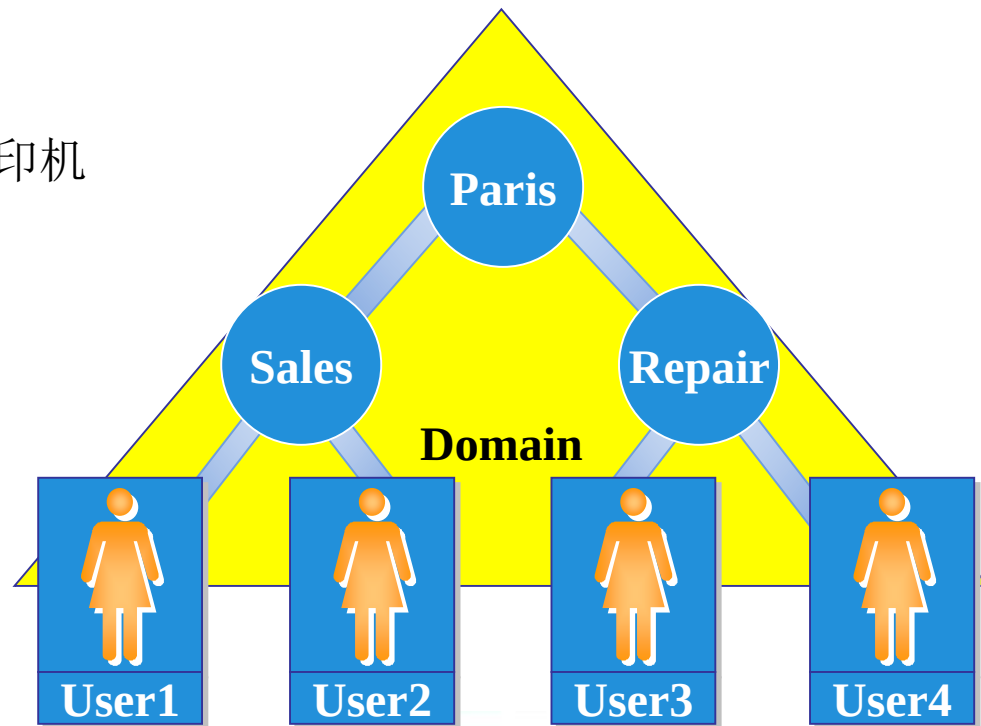
- 根域下面可以建立多层子域，域和子域构建成域树
- 这些域共享相同的架构和配置信息
- 这些域有着邻接的名字空间

森林 (Forrest)



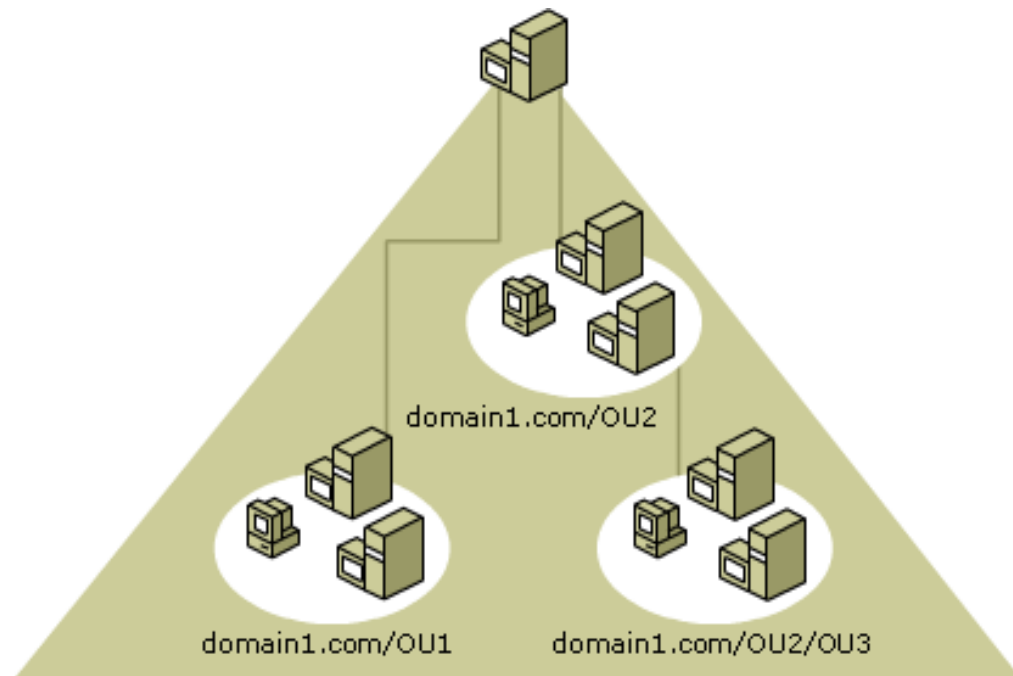
存放对象及其属性的容器——组织单元

- OU是一种类型的目录对象——容器，其作用主要用来委派对用户、组及资源集合的管理权限
 - 控制用户/组对资源的访问
 - 建立/应用组策略对象
 - 实现管理委派
 - 组织具有公共属性的对象，如打印机

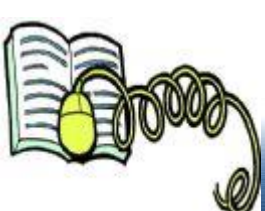
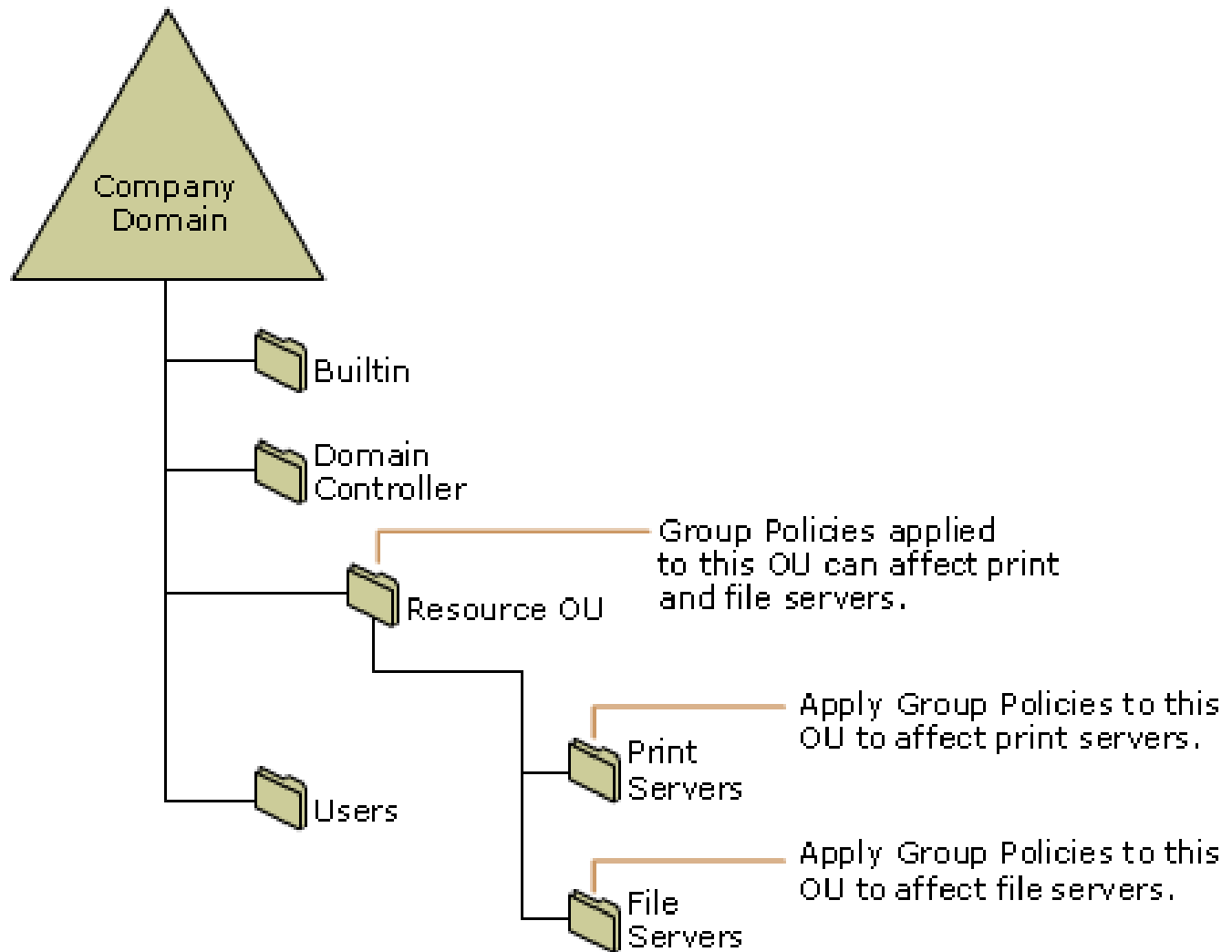


组织单元的划分原则

- 基于部门 OUs
- 基于项目 OUs
- 基于业务功能 OUs
- 基于管理 OUs
- 基于对象 OUs
- 地理位置 OUs



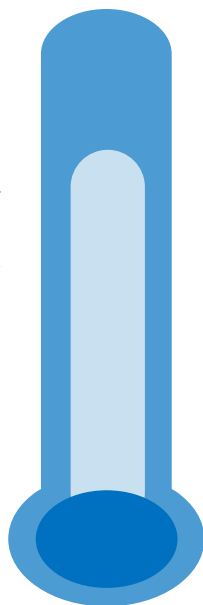
组织单元的划分举例



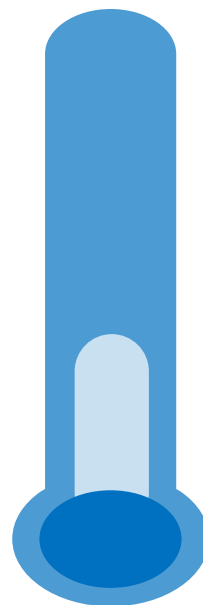
为什么需要活动目录的物理结构

AD物理结构主要是规划站点拓扑，帮助管理员确定在网络的什么地方放置域控制器，以及管理域控制器之间的复制流量和用户登录流量

客户端需要
找到最近的
可用资源



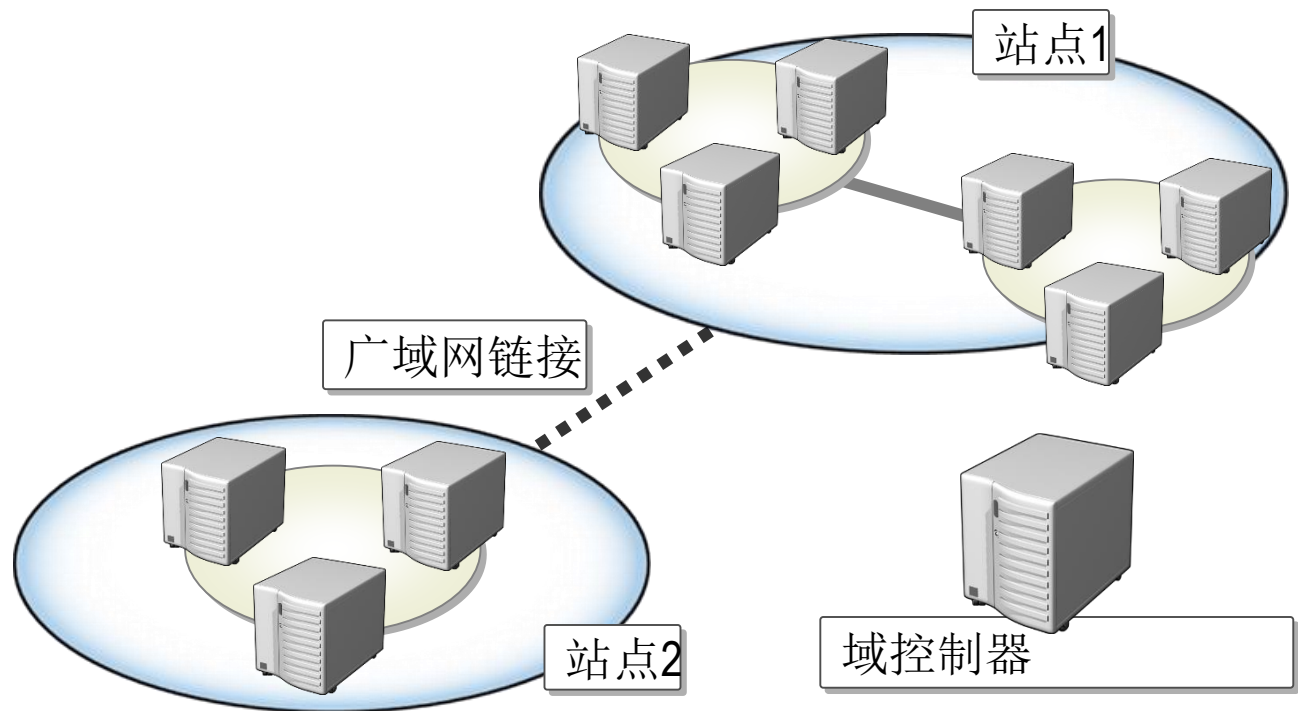
优化复制



考虑到企业的地理分布情况，应该使用多站点拓扑来规划AD物理结构

站点和IP子网

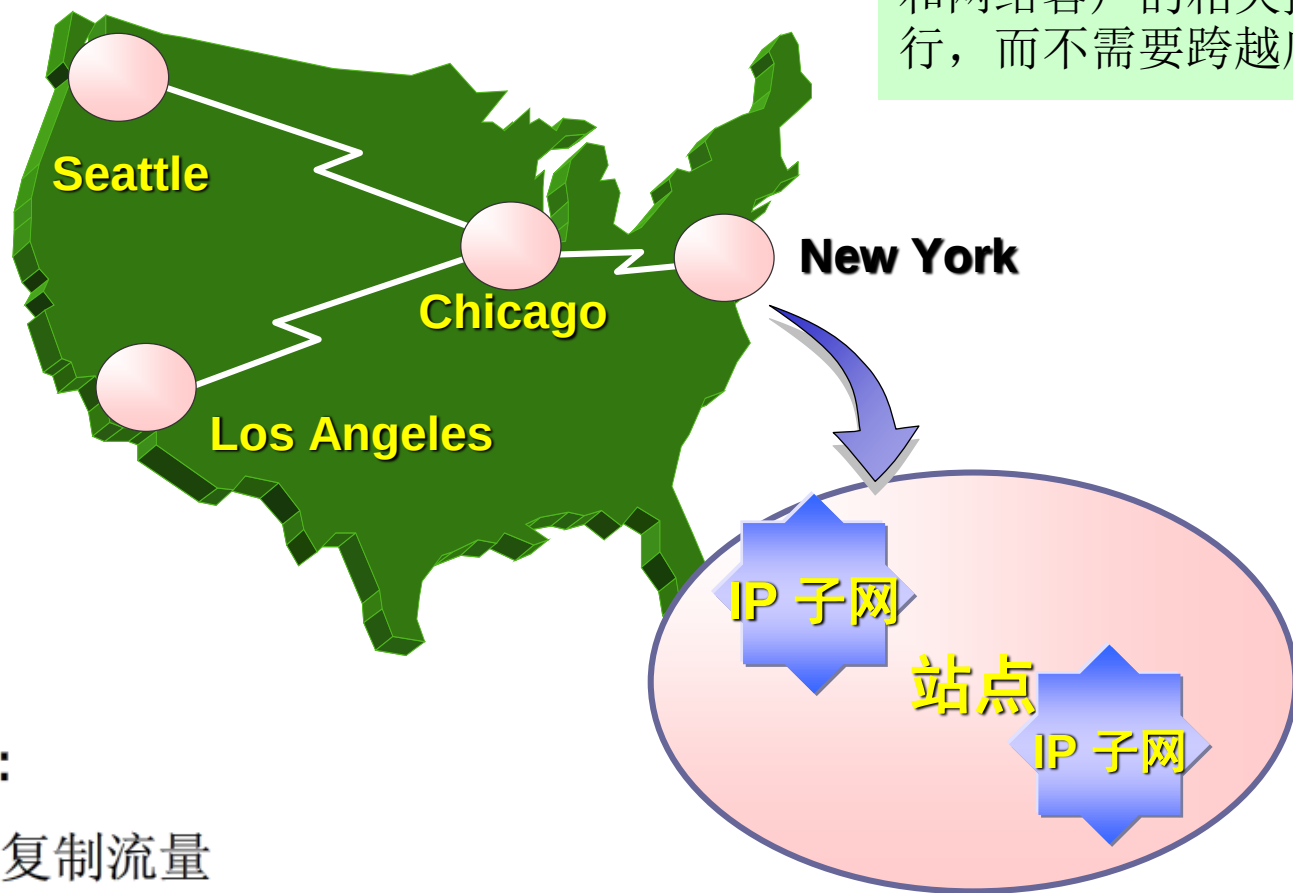
- 每个地理位置中的若干台域控制器可以划分为一个站点
- 站点内部优先同步活动目录数据库，同步后再和其他站点中的域控制器同步



为什么需要活动目录的物理结构

站点反映了活动目录的物理结构

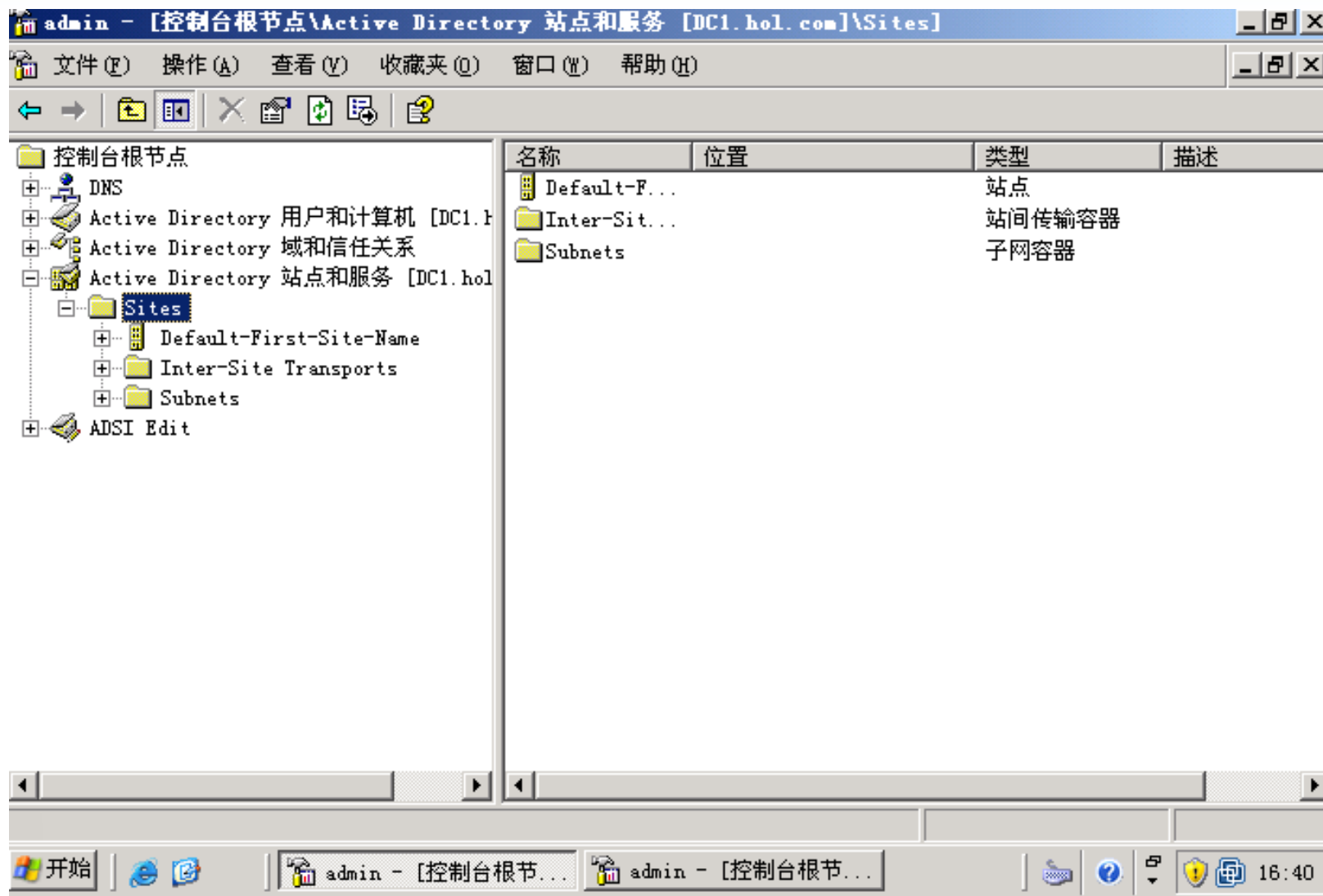
由于站点内的计算机有着良好的连接，因此用户使用站点来使服务器和网络客户的相关操作都在本地进行，而不需要跨越广域网



站点目的:

- 优化复制流量
- 使用户登录到DC，使用一个可靠的、高速的链接

创建站点





AD的组策略

Group Policy

Group Policy is a hierarchical infrastructure that allows a network administrator in charge of Microsoft's Active Directory to implement specific configurations for users and computers. Group Policy can also be used to define user, security and networking policies at the machine level.

Group Policy allows administrators to define options for what users can do on a network – including what files, folders and applications they can access. The collections of user and computer settings are referred to as **Group Policy Objects** (GPOs), which are administered from a central interface called the **Group Policy Management Console**.



组策略GPMC——“一对多”的管理

组策略是Windows Server 2003操作系统中提供的一种重要的更新和配置管理技术。

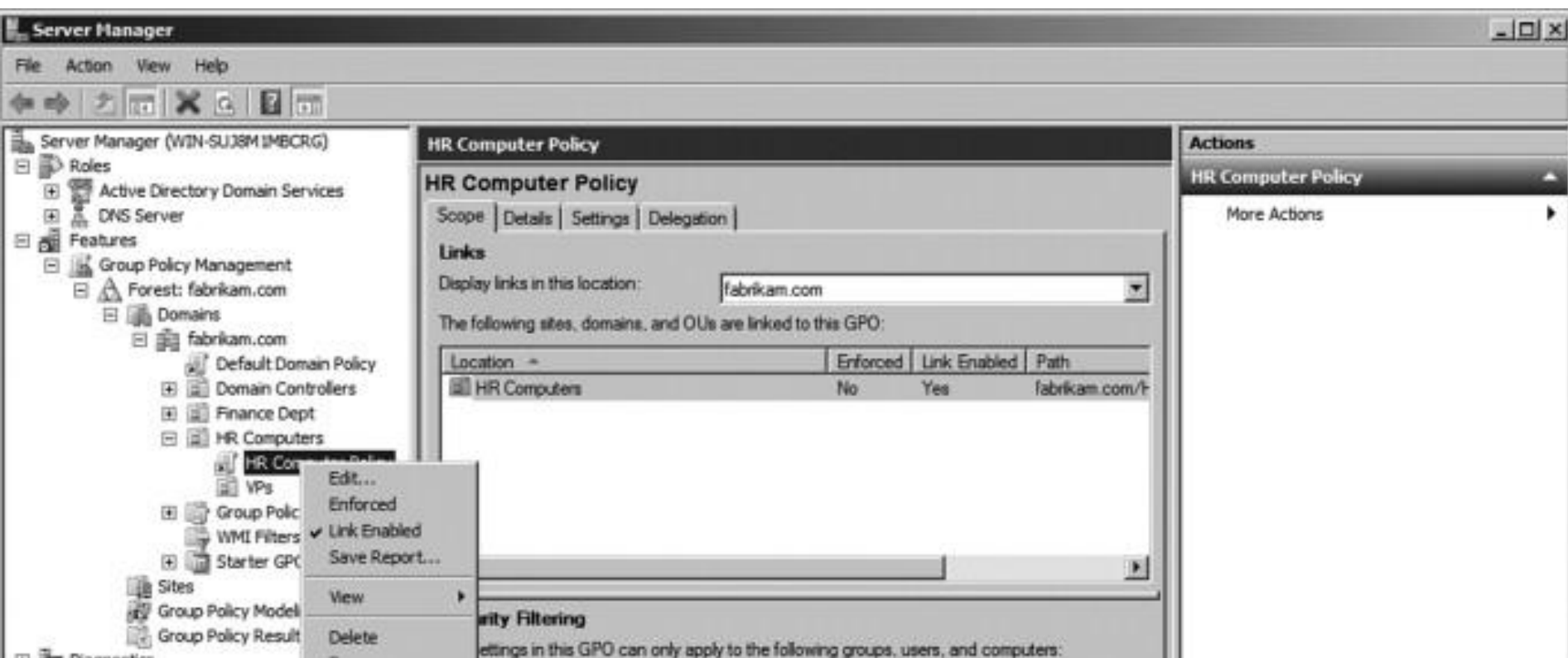
- 系统管理员使用组策略来为计算机和用户组管理桌面配置指定的选项
- 组策略很灵活，它包括如下的一些选项：基于注册表的策略设置、安全设置、软件安装、脚本、计算机启动与关闭、用户登录和注销，文件重定向等
- Windows Server 2003包括几百种可以配置的组策略设置。组策略设置允许企业管理员通过增强和控制用户桌面来减少总的开销

组策略的内容

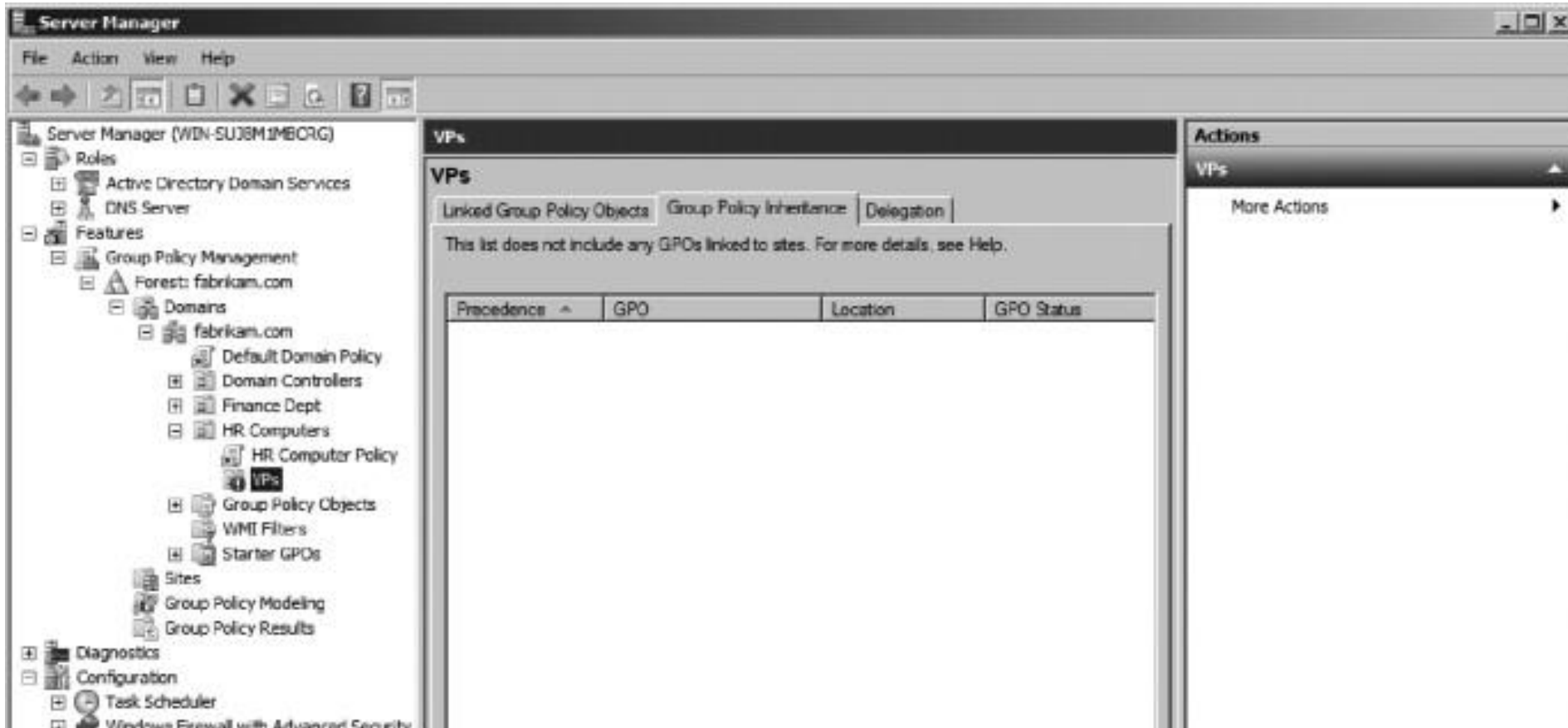
Microsoft

策略	安全设置
DCOM: 安全描述符定义语言 (S...)	没有定义
DCOM: 安全描述符定义语言 (S...)	没有定义
Microsoft 网络服务器: 当登...	已启用
Microsoft 网络服务器: 数字...	已停用
Microsoft 网络服务器: 数字...	已停用
Microsoft 网络服务器: 在挂...	15 分钟
Microsoft 网络客户: 发送未...	已停用
Microsoft 网络客户: 数字签...	已启用
Microsoft 网络客户: 数字签...	已停用
故障恢复控制台: 允许对所有...	已停用
故障恢复控制台: 允许自动系...	已停用
关机: 清理虚拟内存页面文件	已停用
关机: 允许在未登录前关机	已启用
交互式登录: 不显示上次的用...	已停用
交互式登录: 不需要按 CTRL+...	已停用
交互式登录: 可被缓冲保存的...	10 次登录
交互式登录: 要求域控制器身...	已停用
交互式登录: 要求智能卡	没有定义
交互式登录: 用户试图登录时...	没有定义
交互式登录: 在密码到期前提...	14 天
交互式登录: 智能卡移除操作	无操作
设备: 防止用户安装打印机驱...	已停用
设备: 防止安装驱动程序的安装	允许安装但发出警告

Editing GPO Settings

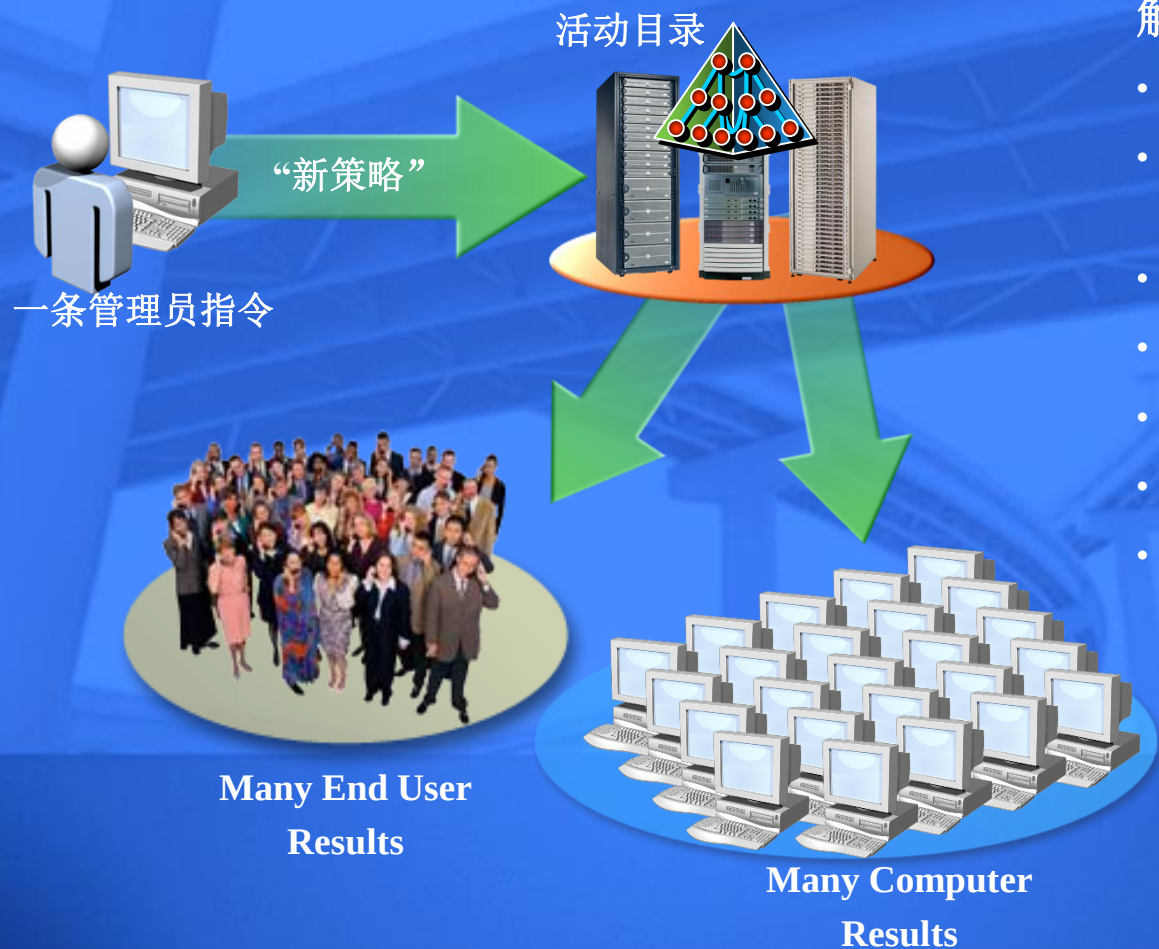


Organizational Unit Blocking Inheritance



组策略的主要优势

Microsoft®

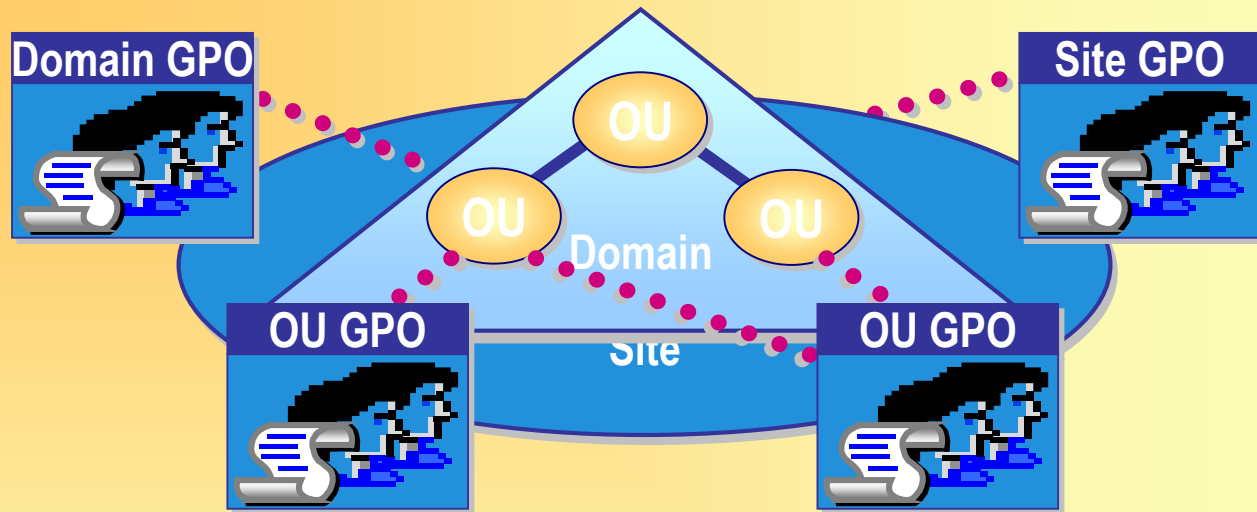


解决方案：组策略

- 策略提供大量定制桌面的管理
- 组策略管理控制台（GPMC）让管理工作更简单
- RsOP得到组策略应用的结果
- 主要优势：
 - 降低管理、支持与培训成本
 - 提升用户工作效率
- 允许极大量的定制项目 – 其扩展性不会牺牲定制的灵活性

组策略对象和组策略容器

Microsoft®



GPO 设置应用于连接在一个Site、域、和OU中的用户和计算机

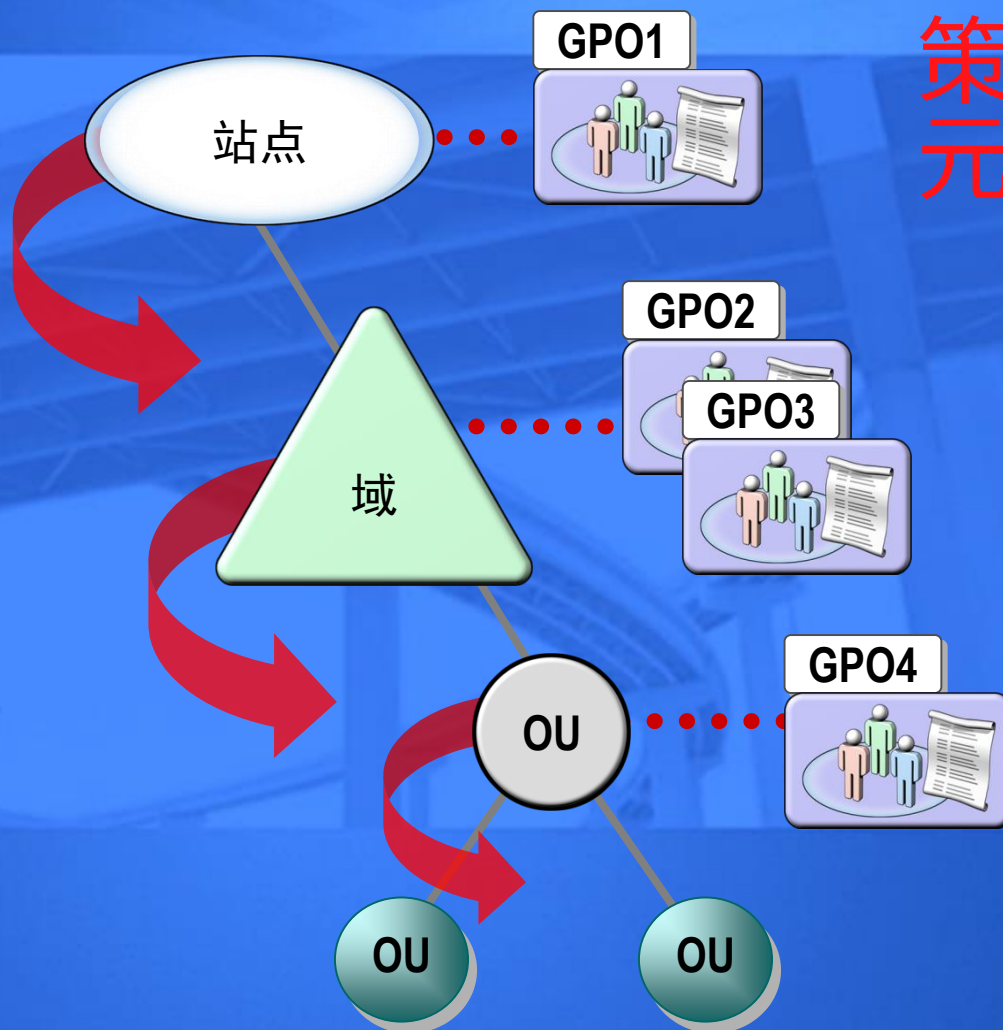
- 一个GPO可以连接在多个Site、域、和OU 上
- 一个Site、域、和OU 上可以连接多个GPO

OU&组策略

An OU is the smallest unit to which an administrator can assign **Group Policy** settings or **account permissions**.

OU是挂载组策略的最小单元

Microsoft®



使用组策略

Microsoft®

- 使用组策略管理客户端安全性
- 使用组软件限制策略
- 使用组策略分发软件

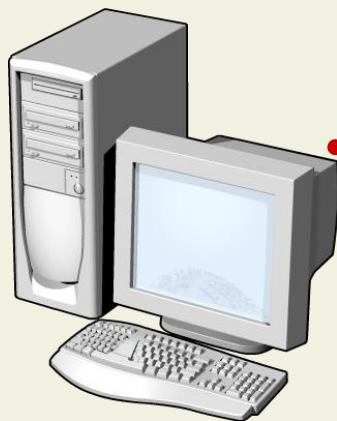


利用组策略部署与管理软件

- 软件生命周期

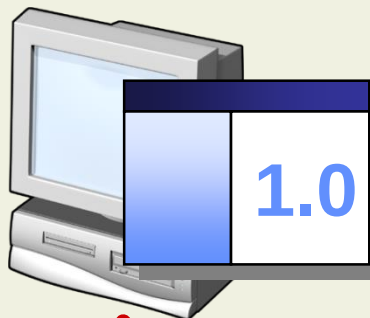
Microsoft®

1



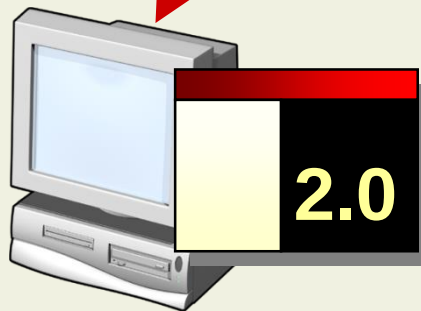
准备

2



部署

3



维护

4

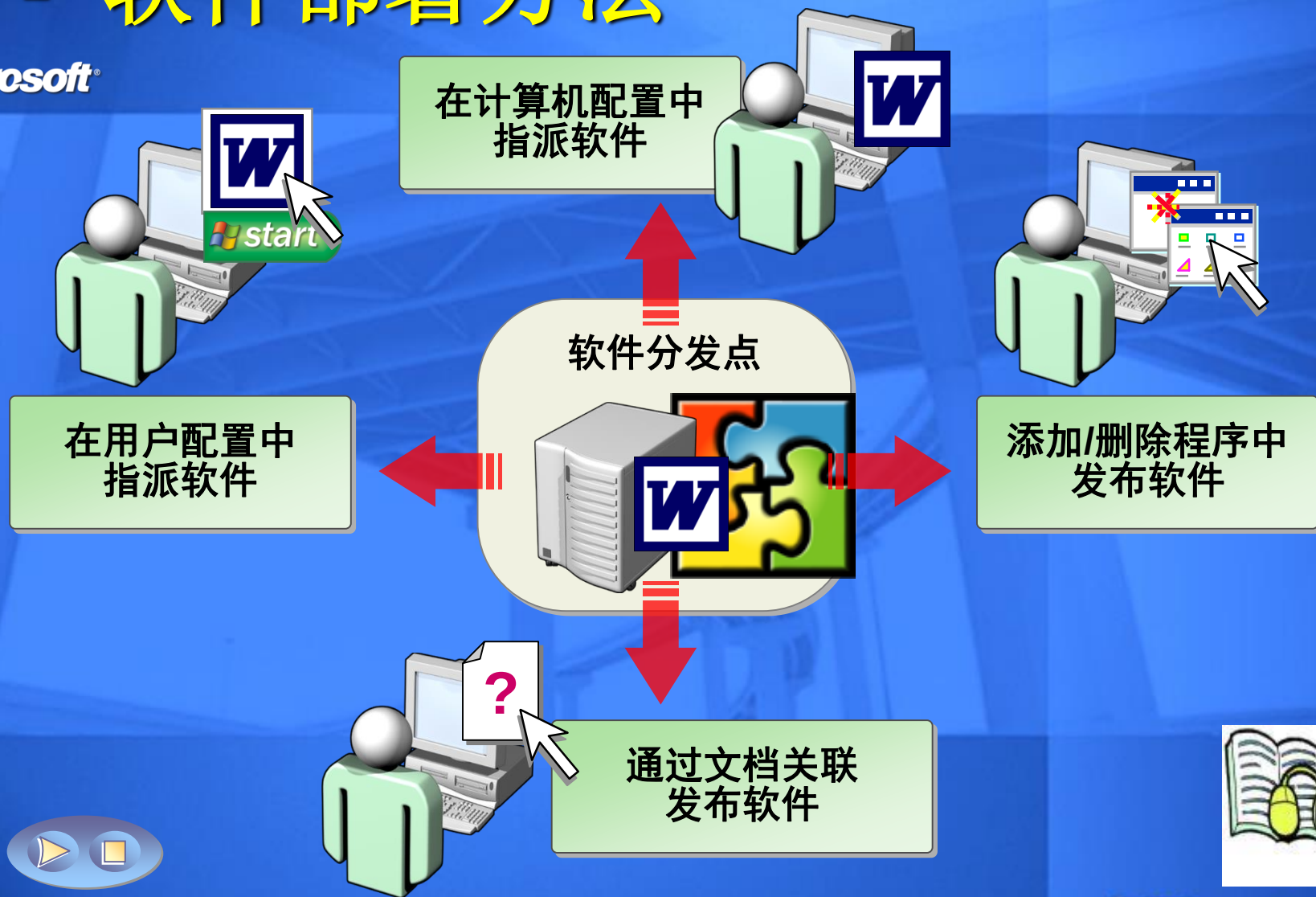


移除

利用组策略部署与管理软件

- 软件部署方法

Microsoft®



Summary of The Class



- Windows对资源的管理方式
WorkGroup vs. Domain
- 活动目录
目录和目录服务、AD的逻辑架构、
AD的物理架构
- 组策略
实现大规模安全管理的“神器”